



**UNIVERSIDAD MAYOR DE SAN
SIMON FACULTAD DE CIENCIAS Y
TECNOLOGIA DIRECCIÓN DE POSGRADO**



Validación de vulnerabilidades web identificadas mediante herramientas automatizadas utilizando la metodología OWASP WSTG para el Portal Web del Servicio de Impuestos Nacionales de Bolivia

**MONOGRAFÍA PRESENTADO PARA OBTENER EL CERTIFICADO
DE DIPLOMADO EN CIBERSEGURIDAD - 1RA VERSIÓN**

POSTULANTE : CORIA ROJAS JOSEPH DAVID

**Cochabamba – Bolivia
2026**

DEDICATORIA

Dedico el presente trabajo a mi familia, por su apoyo incondicional, comprensión y constante motivación durante todo este proceso de formación.

Asimismo, a mis docentes, por compartir sus conocimientos, experiencia y orientación, y a mis compañeros, por el compañerismo y el apoyo brindado a lo largo del diplomado. Cada uno de ellos contribuyó de manera significativa a fortalecer mi interés y compromiso con el ámbito de la ciberseguridad.

AGRADECIMIENTOS

Expreso mi sincero agradecimiento a Dios por brindarme la fortaleza y la perseverancia necesarias para culminar esta investigación. Asimismo, agradezco a mi familia por su apoyo incondicional durante todo el proceso de formación académica y por motivarme constantemente a alcanzar mis objetivos.

De igual manera, agradezco al docente del módulo de Trabajo Final por sus orientaciones, observaciones y recomendaciones, las cuales permitieron fortalecer el desarrollo de la presente monografía. Finalmente, expreso mi reconocimiento a todas las personas que, de manera directa o indirecta, contribuyeron a la realización de este trabajo.

DECLARACIÓN DE ORIGINALIDAD

Cochabamba, julio de 2026

Yo, Joseph David Coria Rojas, con cédula de identidad No. 8787810 Cba, declaro que el trabajo final del Diplomado en Ciberseguridad – 1ra Versión es un trabajo original y carece de cualquier tipo de plagio en cualquiera de sus formas.

Entiendo y acepto que, en caso de encontrarse o evidenciarse elementos que vulneren los derechos de autor y/o propiedad intelectual en el trabajo académico presentado (monografía), seré sujeto a las sanciones administrativas-académicas derivadas de dicha acción u omisión, incluyendo el retiro del certificado y/o títulos respectivos.

El título de mi monografía es: **“Validación de vulnerabilidades web identificadas mediante herramientas automatizadas utilizando la metodología OWASP WSTG para el Portal Web del Servicio de Impuestos Nacionales de Bolivia”**.

Joseph David Coria Rojas

Msc. Ing. Marcelo Antezana

COORDINADOR DEL PROGRAMA

INTRODUCCIÓN.....	10
1. ANTECEDENTES GENERALES.....	10
2. ANTECEDENTES ESPECÍFICOS.....	10
3. IDENTIFICACIÓN DEL PROBLEMA.....	11
3.1 Identificación del Problema.....	11
3.2 Descripción del Problema.....	11
3.3 Formulación del Problema.....	12
4 Objetivos.....	12
4.1. Objetivo general.....	12
1.5 Objetivos específicos.....	12
5 Justificación.....	12
5.1 Justificación tecnológica.....	12
5.2 Justificación metodológica.....	13
5.3 Justificación social.....	13
5.4 Justificación económica.....	14
6. ALCANCE Y Limitaciones.....	14
6.1 Alcance Temático.....	14
6.2 Alcance Espacial.....	14
6.3 Alcance Temporal.....	14
6.4 Limitaciones.....	14
7. NIVEL DE INVESTIGACIÓN.....	15
CAPÍTULO I.....	16
MARCO TEÓRICO.....	16
1.1 Introducción al marco teórico.....	16
1.2 Seguridad de aplicaciones web.....	16
1.3 Vulnerabilidades web.....	17
1.4 Pruebas de penetración (Pentesting).....	17
1.5 Reconocimiento en pruebas de penetración.....	18
1.6 Herramientas automatizadas para reconocimiento y análisis de vulnerabilidades	20
1.6.1 WhatWeb.....	20
1.6.2 Wappalyzer.....	20
1.6.3 Nikto.....	21
1.6.4 Nuclei.....	21
1.6.5 Burp Suite Community.....	21
1.7 OWASP.....	21
1.8 OWASP Web Security Testing Guide (WSTG).....	22
1.9 Validación manual de vulnerabilidades.....	23
1.10. Conclusiones de marco teórico.....	23
Capítulo II.....	24
DIAGNÓSTICO DEL SISTEMA Y AMENAZAS.....	24

2.1 Introducción capitular.....	25
2.2 Metodología del diagnóstico.....	25
2.3 Identificación del objetivo.....	25
2.4 Identificación de tecnologías (WhatWeb y Wappalyzer).....	26
2.4.1 WhatWeb.....	26
2.4.2 Wappalyzer.....	27
2.5 Análisis preliminar de vulnerabilidades (Nikto y Nuclei).....	29
2.5.1 Resultados obtenidos con Nikto.....	29
2.5.2 Resultados obtenidos con Nuclei.....	31
2.6 Fortalezas identificadas.....	33
2.6.1 Uso de comunicaciones cifradas mediante HTTPS.....	33
2.6.2 Implementación de mecanismos de protección frente al reconocimiento automatizado.....	34
2.6.3 Configuración de políticas de autenticación del correo electrónico.....	34
2.6.4 Consistencia tecnológica de la infraestructura.....	34
2.7 Debilidades y problemáticas identificadas.....	35
2.7.1 Ausencia de cabeceras HTTP de seguridad.....	35
2.7.2 Cookie sin atributo Secure.....	35
2.7.3 Divulgación de información tecnológica.....	35
2.8 Conclusiones capitulares.....	36
Capítulo III.....	37
PROPUESTA.....	37
3.1 Introducción.....	37
3.2 Descripción general.....	38
3.3 Ejecución de los casos de prueba.....	38
3.3.1 WSTG-INFO-02 Divulgación de la versión del servidor web.....	38
3.3.2 WSTG-INFO-08 Divulgación de tecnologías y framework de aplicación.....	39
3.3.3 WSTG-CONF-02 Exposición del endpoint de la API REST (wp-json).....	39
3.3.4 WSTG-CONF-07 / WSTG-CONF-14 Validación de cabeceras HTTP de seguridad.....	40
3.3.5 WSTG-SESS-02 Validación de atributos de cookies de sesión.....	41
3.3.6 WSTG-CRYP-01 Configuración de seguridad de la capa de transporte (TLS).....	43
3.3.7 WSTG-CONF-06 Métodos HTTP habilitados.....	43
3.3.8 WSTG-ERRH-01 Manejo de errores.....	44
3.3.9 Verificación complementaria mediante herramientas de análisis pasivo.....	45
3.4 Clasificación de los hallazgos.....	49
3.5 Resultados obtenidos.....	51
3.6 Conclusiones capitulares.....	52
Capítulo IV.....	52
VALIDACIÓN.....	52
4.1 Introducción capitular.....	53

4.2 Metodología de validación.....	53
4.3 Escenarios y casos de prueba considerados.....	53
4.4 Análisis comparativo: reconocimiento automatizado frente a validación asistida por OWASP WSTG.....	55
4.5 Interpretación de resultados en relación con los objetivos.....	55
4.6 Conclusiones capitulares.....	56
CONCLUSIONES Y RECOMENDACIONES.....	56
Conclusiones.....	57
Recomendaciones.....	57
REFERENCIAS.....	59
ANEXOS.....	60
Anexo A. Herramientas utilizadas.....	60
Anexo B. Comandos ejecutados.....	61
Anexo C. Resultados completos de Nikto.....	61
Anexo D. Resultados completos de Nuclei.....	63
Anexo E. Resultados de Security Headers.....	64
Anexo F. Resultados de Mozilla Observatory.....	65

Índice de Tablas

Tabla 2.1. Tecnologías identificadas mediante Wappalyzer.....	28
Tabla 2.2. Hallazgos identificados mediante Nikto.....	30
Tabla 2.3. Hallazgos identificados mediante Nuclei.....	32
Tabla 2.4. Fortalezas identificadas.....	34
Tabla 2.5. Hallazgos que requieren validación.....	36
Tabla 3.1. Resultado de la validación manual de la cookie de sesión.....	42
Tabla 3.2 Clasificación de los hallazgos validados según resultado, categoría	
Tabla 4.1 Matriz de trazabilidad de los hallazgos validados.....	54

ÍNDICE DE FIGURAS

Figura 2.1 Página principal del Portal Web del Servicio de Impuestos Nacionales de Bolivia.....	26
Figura 2.2. Resultado obtenido mediante WhatWeb.....	27
Figura 2.3. Tecnologías identificadas mediante Wappalyzer.....	28
Figura 2.4. Resultado del análisis automatizado realizado mediante Nikto.....	30
Figura 2.5. Resultado del análisis automatizado realizado mediante Nuclei.....	32
Figura 3.1. Validación manual de las cabeceras HTTP del portal web mediante Burp Suite Community.....	41
Figura 3.2. Verificación manual de los atributos de la cookie cookiesession1 mediante las herramientas de desarrollo de Google Chrome.....	42
Figura 3.3 Resultado de la validación de protocolos TLS mediante OpenSSL.....	43
Figura 3.4 Resultado de la validación de métodos HTTP habilitados.....	44
Figura 3.5 Resultado de la solicitud a una ruta inexistente del portal.....	45
Figura 3.6 Reporte de Security Headers sobre el portal evaluado.....	46
Figura 3.7 Reporte de Mozilla HTTP Observatory sobre el portal evaluado.....	47
Figura 3.8 Reporte de Qualys SSL Labs sobre la configuración de la capa de transporte del portal evaluado.....	48
Figura 3.9 Consulta de Certificate Transparency del dominio impuestos.gob.bo mediante crt.sh.....	49

INTRODUCCIÓN

1. ANTECEDENTES GENERALES

En los últimos años, la transformación digital ha impulsado a organizaciones públicas y privadas a ofrecer una gran cantidad de servicios mediante plataformas web. Esta evolución ha permitido optimizar procesos, ampliar la cobertura de atención y facilitar el acceso de los usuarios a diversos servicios; sin embargo, también ha incrementado la exposición de estos sistemas a amenazas cibernéticas cada vez más sofisticadas (Shahid et al., 2022).

De acuerdo con la Open Worldwide Application Security Project (OWASP), las aplicaciones web constituyen uno de los principales objetivos de los ataques informáticos debido a que procesan información sensible y, en muchos casos, presentan fallas derivadas de errores de programación, configuraciones inseguras o una validación insuficiente de los controles de seguridad. Vulnerabilidades como la inyección de código, el Cross-Site Scripting (XSS), la autenticación deficiente y los errores en el control de acceso continúan siendo algunas de las más explotadas por los atacantes (OWASP Foundation [OWASP], 2021).

Frente a este escenario, la evaluación periódica de la seguridad de las aplicaciones web se ha convertido en una práctica fundamental dentro de la ciberseguridad. Para ello se emplean metodologías reconocidas internacionalmente, como la **OWASP Web Security Testing Guide (WSTG)**, la cual proporciona procedimientos estandarizados para identificar y validar vulnerabilidades durante las diferentes fases de una evaluación de seguridad (OWASP, 2020).

Asimismo, el uso de herramientas automatizadas de reconocimiento y análisis de vulnerabilidades permite realizar evaluaciones preliminares de manera rápida; sin embargo, los resultados obtenidos requieren un proceso de validación para determinar cuáles representan riesgos reales y cuáles corresponden a falsos positivos.

2. ANTECEDENTES ESPECÍFICOS

En Bolivia, el Servicio de Impuestos Nacionales (SIN) ofrece múltiples servicios digitales mediante su portal web institucional, permitiendo a contribuyentes y empresas realizar consultas, declaraciones, pagos y otros trámites tributarios de manera electrónica. Debido a la naturaleza de la información procesada por estos sistemas, la seguridad del portal representa un aspecto crítico para garantizar la disponibilidad, integridad y confidencialidad de los datos (Banco Interamericano de Desarrollo [BID], 2025).

Diversas investigaciones y estudios en el ámbito de la seguridad informática han demostrado que la utilización exclusiva de herramientas automatizadas no siempre proporciona resultados completamente confiables, ya que estas pueden generar falsos positivos o dejar

de detectar determinadas vulnerabilidades (Abdulghaffar et al., 2023). Por esta razón, organismos especializados como OWASP recomiendan complementar los resultados obtenidos mediante herramientas automáticas con procedimientos de validación basados en metodologías estandarizadas.

En este contexto, la metodología **OWASP Web Security Testing Guide (WSTG)** constituye una referencia ampliamente aceptada para validar vulnerabilidades identificadas durante pruebas de penetración de caja negra, permitiendo verificar de forma sistemática la existencia y el impacto potencial de los hallazgos detectados (OWASP, 2020).

La presente investigación toma como caso de estudio el Portal Web del Servicio de Impuestos Nacionales de Bolivia, aplicando una metodología reconocida internacionalmente para validar los resultados obtenidos mediante herramientas automatizadas de evaluación de seguridad, sin realizar acciones que comprometan la disponibilidad o integridad del sistema evaluado.

3. IDENTIFICACIÓN DEL PROBLEMA

3.1 Identificación del Problema

El incremento de los servicios públicos digitales ha convertido a las aplicaciones web gubernamentales en un objetivo frecuente de ataques informáticos. Estas plataformas administran información crítica de ciudadanos e instituciones, por lo que la existencia de vulnerabilidades representa un riesgo para la seguridad de la información y la continuidad de los servicios.

Aunque existen diversas herramientas automatizadas para identificar posibles vulnerabilidades, los resultados obtenidos no siempre reflejan con precisión el estado real de seguridad de una aplicación web, debido a la presencia de falsos positivos o hallazgos que requieren verificación manual.

3.2 Descripción del Problema

El Portal Web del Servicio de Impuestos Nacionales constituye uno de los principales medios de interacción entre la administración tributaria y los contribuyentes en Bolivia. A través de este portal se realizan consultas, trámites y servicios que requieren altos niveles de disponibilidad y seguridad.

Las herramientas automatizadas de análisis de vulnerabilidades permiten identificar rápidamente posibles debilidades de seguridad; sin embargo, por sí solas no permiten determinar con certeza la validez de todos los hallazgos encontrados. Esta situación puede generar diagnósticos imprecisos, ocasionando que recursos sean destinados a vulnerabilidades inexistentes o que riesgos reales pasen desapercibidos.

La metodología OWASP Web Security Testing Guide proporciona procedimientos técnicos que permiten validar sistemáticamente los resultados obtenidos por estas herramientas, reduciendo la incertidumbre durante el proceso de evaluación y proporcionando evidencia técnica suficiente para determinar el nivel real de exposición del sistema evaluado.

Por ello, surge la necesidad de realizar una validación metodológica de las vulnerabilidades identificadas mediante herramientas automatizadas sobre el Portal Web del Servicio de Impuestos Nacionales de Bolivia.

3.3 Formulación del Problema

¿Cómo contribuye la metodología OWASP Web Security Testing Guide en la validación de las vulnerabilidades identificadas mediante herramientas automatizadas en el Portal Web del Servicio de Impuestos Nacionales de Bolivia?

4 Objetivos

4.1. Objetivo general

Validar las vulnerabilidades web identificadas mediante herramientas automatizadas utilizando la metodología OWASP Web Security Testing Guide (WSTG) en el Portal Web del Servicio de Impuestos Nacionales de Bolivia.

4.2 Objetivos específicos

1. Identificar las tecnologías y servicios expuestos del Portal Web del Servicio de Impuestos Nacionales mediante herramientas de reconocimiento pasivo y activo.
2. Detectar posibles vulnerabilidades web utilizando herramientas automatizadas de análisis de seguridad.
3. Clasificar los hallazgos obtenidos según su nivel de criticidad y su relación con las categorías de seguridad web.
4. Validar manualmente las vulnerabilidades identificadas mediante la metodología OWASP Web Security Testing Guide para determinar la existencia de vulnerabilidades reales y falsos positivos.
5. Proponer recomendaciones orientadas a fortalecer la seguridad del portal web con base en los resultados obtenidos durante la validación.

5 Justificación

5.1 Justificación tecnológica

La seguridad de las aplicaciones web representa uno de los principales desafíos para las organizaciones debido a la constante aparición de nuevas vulnerabilidades y técnicas de ataque. Actualmente existen diversas herramientas automatizadas que permiten identificar posibles debilidades en aplicaciones web; sin embargo, sus resultados requieren un proceso de validación que permita diferenciar vulnerabilidades reales de falsos positivos (Shahid et al., 2022).

La presente investigación empleará herramientas automatizadas de reconocimiento y análisis de vulnerabilidades en conjunto con la metodología **OWASP Web Security Testing Guide (WSTG)**, reconocida internacionalmente como una guía de referencia para la realización de pruebas de seguridad en aplicaciones web (OWASP, 2020). La combinación de estas tecnologías permitirá obtener una evaluación más precisa y confiable del Portal Web del Servicio de Impuestos Nacionales de Bolivia, en línea con enfoques recientes que combinan varias herramientas automatizadas para reducir la tasa de falsos positivos (Abdulhaffar et al., 2023).

5.2 Justificación metodológica

Desde el punto de vista metodológico, la investigación propone un procedimiento estructurado para validar los hallazgos obtenidos mediante herramientas automatizadas utilizando como referencia la metodología OWASP WSTG (OWASP, 2020), complementada con las fases de prueba técnica descritas por el NIST para la evaluación de la seguridad de la información (Scarfone et al., 2008).

Este enfoque permitirá establecer un proceso ordenado de reconocimiento, identificación de vulnerabilidades, clasificación de hallazgos y validación manual, contribuyendo a la generación de resultados técnicamente sustentados y replicables en futuras evaluaciones de seguridad de aplicaciones web.

5.3 Justificación social

Los portales web gubernamentales almacenan y procesan información de interés para ciudadanos y organizaciones, por lo que su seguridad constituye un aspecto fundamental para preservar la confianza en los servicios digitales (BID, 2025).

La validación de vulnerabilidades contribuye indirectamente a fortalecer las buenas prácticas de seguridad informática, promoviendo evaluaciones más precisas que permitan identificar riesgos potenciales antes de que puedan ser aprovechados por actores maliciosos, en un contexto regional donde Bolivia se encuentra entre los países más afectados por incidentes de ciberseguridad (Flor-Unda et al., 2023).

Es importante señalar que esta investigación tiene fines exclusivamente académicos y se desarrollará respetando principios éticos, limitándose a actividades de reconocimiento y validación controlada sin afectar la disponibilidad ni el funcionamiento del portal evaluado.

5.4 Justificación económica

El uso de herramientas automatizadas de código abierto, complementadas con una metodología reconocida internacionalmente como OWASP WSTG (OWASP, 2020), permite realizar evaluaciones de seguridad con una inversión reducida en comparación con soluciones comerciales especializadas, considerando que diversas herramientas de código abierto han mostrado un desempeño comparable al de escáneres comerciales en la detección de vulnerabilidades (Shahid et al., 2022).

Asimismo, una correcta validación de vulnerabilidades favorece la adecuada priorización de riesgos, evitando la asignación innecesaria de recursos para corregir falsos positivos y concentrando los esfuerzos en vulnerabilidades que realmente representan un impacto para la organización.

6. ALCANCE Y Limitaciones

6.1 Alcance Temático

La investigación se desarrolla en el área de la ciberseguridad, específicamente en el ámbito del hacking ético y la evaluación de seguridad de aplicaciones web. El estudio comprende la identificación de vulnerabilidades mediante herramientas automatizadas y la validación de los resultados utilizando la metodología OWASP Web Security Testing Guide (WSTG). No se contempla la explotación de vulnerabilidades ni la ejecución de pruebas que puedan afectar la disponibilidad o integridad del sistema evaluado.

6.2 Alcance Espacial

La investigación se realizará sobre el Portal Web institucional del Servicio de Impuestos Nacionales del Estado Plurinacional de Bolivia, utilizando únicamente información accesible públicamente y aplicando pruebas no intrusivas conforme a principios éticos y buenas prácticas de evaluación de seguridad.

6.3 Alcance Temporal

La investigación se desarrollará durante la gestión académica 2026, en el marco del Diplomado en Ciberseguridad, comprendiendo el período destinado a la planificación, ejecución de las pruebas, validación de resultados, análisis de hallazgos y elaboración de la monografía.

6.4 Limitaciones

La investigación se limitará exclusivamente al análisis de información públicamente accesible y a pruebas de seguridad de carácter no intrusivo autorizadas dentro del alcance académico del estudio.

No se realizarán actividades que impliquen explotación de vulnerabilidades, modificación de información, interrupción de servicios, acceso no autorizado ni pruebas que puedan afectar la disponibilidad o integridad del Portal Web del Servicio de Impuestos Nacionales.

Asimismo, la investigación dependerá del estado operativo del portal durante el periodo de ejecución y de la información proporcionada por las herramientas automatizadas utilizadas en la evaluación.

7. NIVEL DE INVESTIGACIÓN

La presente investigación corresponde a un **nivel descriptivo con enfoque aplicado**.

Es descriptiva porque busca identificar, analizar y validar las vulnerabilidades detectadas mediante herramientas automatizadas en una aplicación web específica, documentando sus características, posibles impactos y nivel de riesgo.

Asimismo, posee un carácter aplicado debido a que utiliza metodologías, herramientas y conocimientos propios del hacking ético y de la seguridad de aplicaciones web para resolver un problema concreto en un caso de estudio real, generando resultados que pueden servir como referencia para futuras evaluaciones de seguridad en sistemas similares.

CAPÍTULO I

MARCO TEÓRICO

1.1 Introducción al marco teórico

Antes de validar cualquier vulnerabilidad detectada por una herramienta automatizada, resulta indispensable comprender los fundamentos conceptuales que sostienen dicha validación. Un hallazgo reportado por un escáner no tiene valor por sí mismo si quien lo interpreta desconoce qué representa técnicamente, cómo se clasifica y qué lo diferencia de un falso positivo. Por esta razón, el presente capítulo desarrolla el cuerpo teórico necesario para sustentar la investigación sobre la validación de vulnerabilidades web mediante la metodología OWASP Web Security Testing Guide (WSTG) en el Portal Web del Servicio de Impuestos Nacionales de Bolivia.

El capítulo se organiza siguiendo una lógica progresiva: se parte de un panorama general sobre la seguridad de las aplicaciones web y los riesgos que enfrentan actualmente, para luego profundizar en el concepto de vulnerabilidad y en los sistemas de clasificación más utilizados por la comunidad de ciberseguridad, como el CWE y el CVE. A continuación, se introduce el pentesting como disciplina y se detallan sus distintas modalidades, prestando especial atención a las pruebas de caja negra, por ser el enfoque adoptado en este trabajo. Posteriormente se abordan las técnicas de reconocimiento que preceden a cualquier evaluación técnica, así como las principales herramientas automatizadas empleadas en esta investigación.

La parte central del capítulo está dedicada a OWASP como organización y, de manera particular, a la metodología WSTG, eje metodológico de todo el proyecto. Finalmente, se cierra el capítulo con una discusión sobre la validación manual de vulnerabilidades, etapa que conecta directamente los resultados de las herramientas automatizadas con el procedimiento de comprobación técnica que se aplicará sobre el caso de estudio. En conjunto, estos apartados construyen el marco conceptual que permitirá interpretar, clasificar y validar con criterio técnico los hallazgos que se obtengan durante la fase práctica de la investigación.

1.2 Seguridad de aplicaciones web

Evolución de las aplicaciones web. Las aplicaciones web han pasado de ser documentos estáticos de solo lectura a convertirse en sistemas complejos que gestionan transacciones, datos personales y procesos críticos para empresas, gobiernos y ciudadanos. Este crecimiento acelerado en el uso de aplicaciones web ha estado acompañado de un incremento proporcional en la superficie de ataque disponible para actores maliciosos (Shahid et al., 2022).

Importancia de la seguridad. La seguridad de las aplicaciones web dejó de ser un aspecto opcional para convertirse en un requisito operativo, particularmente en sectores como la administración pública, donde los portales institucionales concentran información sensible de contribuyentes, procesos de pago y trámites que requieren alta disponibilidad (Banco Interamericano de Desarrollo [BID], 2025).

Amenazas actuales. Entre las amenazas más recurrentes se encuentran la inyección de código, las fallas de control de acceso, las configuraciones de seguridad deficientes y los errores de autenticación, categorías que ocupan las primeras posiciones del listado OWASP Top 10:2021 (OWASP, 2021).

Riesgos. Estos riesgos no son exclusivamente técnicos: también implican consecuencias sociales y económicas, más aún en una región donde países como Bolivia figuran entre los más afectados por incidentes de ciberseguridad en los últimos años (Flor-Unda et al., 2023).

1.3 Vulnerabilidades web

Qué es una vulnerabilidad. Una vulnerabilidad puede definirse como una debilidad presente en un sistema de información que, de ser explotada, permite comprometer su confidencialidad, integridad o disponibilidad (Scarfone et al., 2008).

Clasificación. Para ordenar y describir estas debilidades de manera estandarizada, la comunidad de ciberseguridad recurre a catálogos como el Common Weakness Enumeration (CWE), un diccionario de tipos de debilidades de software y hardware desarrollado y mantenido por la corporación MITRE (MITRE Corporation, n.d.-b).

OWASP Top 10. En el ámbito específico de aplicaciones web, el listado OWASP Top 10:2021 constituye la referencia más citada, agrupando los riesgos más críticos en diez categorías, entre ellas la pérdida de control de acceso, las fallas criptográficas, la inyección, el diseño inseguro y las configuraciones de seguridad incorrectas (OWASP, 2021).

CWE. Cada entrada del CWE describe un tipo específico de debilidad por ejemplo, la neutralización inadecuada de entradas que provoca Cross-Site Scripting y sirve como lenguaje común entre desarrolladores, auditores y herramientas de análisis (MITRE Corporation, n.d.-b).

CVE. A diferencia del CWE, que cataloga tipos de debilidades, el sistema Common Vulnerabilities and Exposures (CVE) identifica instancias concretas de vulnerabilidades ya divulgadas públicamente en productos de software específicos, mediante un identificador único que facilita su seguimiento entre distintas bases de datos y herramientas (MITRE Corporation, n.d.-a).

1.4 Pruebas de penetración (Pentesting)

Definición. Una prueba de penetración es un ejercicio de seguridad ofensiva controlada en el que se simulan las técnicas empleadas por un atacante real, con el fin de identificar y validar vulnerabilidades explotables en un sistema autorizado para su evaluación (Scarfone et al., 2008).

Tipos. Las pruebas de penetración se clasifican principalmente según el nivel de conocimiento previo que se otorga al equipo evaluador, distinguiéndose tres modalidades: caja negra, caja gris y caja blanca (Scarfone et al., 2008).

Caja negra. En la modalidad de caja negra, el evaluador no recibe información previa sobre la arquitectura, el código fuente o la configuración interna del sistema, replicando así la perspectiva de un atacante externo (Scarfone et al., 2008). Esta es la modalidad adoptada en la presente investigación, dado que la evaluación se realiza sobre el portal público del Servicio de Impuestos Nacionales sin acceso privilegiado a su infraestructura.

Caja gris. En la modalidad de caja gris, el evaluador dispone de información parcial, como credenciales de bajo privilegio o documentación limitada, lo que permite combinar el realismo de un ataque externo con mayor profundidad en ciertas áreas del sistema (Scarfone et al., 2008).

Caja blanca. En la modalidad de caja blanca, el evaluador tiene acceso completo al código fuente, la arquitectura y la documentación técnica del sistema, lo que favorece un análisis exhaustivo, aunque requiere mayor tiempo de revisión (Scarfone et al., 2008).

Este punto conecta directamente con el presente trabajo, puesto que la metodología OWASP WSTG está orientada principalmente a la ejecución de pruebas de caja negra y caja gris sobre aplicaciones en producción (OWASP, 2020).

1.5 Reconocimiento en pruebas de penetración

Toda prueba de penetración de caja negra comienza con una fase de reconocimiento, cuyo propósito es recopilar la mayor cantidad de información posible sobre el objetivo antes de ejecutar pruebas activas (Scarfone et al., 2008). La metodología OWASP WSTG agrupa estas actividades bajo la categoría de Recopilación de Información (Information Gathering), la primera de las doce categorías de prueba que la componen (OWASP, 2020).

Footprinting. El *footprinting* corresponde al proceso de recopilación de información pública relacionada con el sistema objetivo. Esta actividad se desarrolla antes de interactuar directamente con la aplicación y tiene como propósito obtener datos generales acerca de la organización, infraestructura tecnológica, dominios registrados, direcciones IP, certificados digitales, tecnologías utilizadas y otros elementos que permitan comprender el entorno donde opera la aplicación (Weidman, 2014).

Las técnicas de *footprinting* pueden clasificarse en activas y pasivas. Las técnicas pasivas obtienen información proveniente de fuentes abiertas sin establecer interacción directa con el

sistema objetivo, mientras que las técnicas activas implican consultas o solicitudes realizadas directamente contra el servidor evaluado.

En el contexto de la presente investigación se prioriza el empleo de técnicas de reconocimiento compatibles con una evaluación ética y autorizada, limitándose a la recopilación de información necesaria para identificar las tecnologías implementadas en el Portal Web del Servicio de Impuestos Nacionales y preparar la posterior fase de validación de vulnerabilidades.

Fingerprinting. Una vez recopilada la información general sobre el sistema objetivo, la siguiente actividad consiste en identificar con mayor precisión las tecnologías que conforman la aplicación web. Este proceso recibe el nombre de *fingerprinting* y permite determinar aspectos como el servidor web utilizado, sistema operativo, gestor de contenidos, frameworks de desarrollo, bibliotecas JavaScript, lenguaje de programación y otros componentes tecnológicos (OWASP, 2020) .

El *fingerprinting* resulta especialmente importante debido a que muchas vulnerabilidades conocidas afectan únicamente versiones específicas de determinados productos. Por ejemplo, conocer la versión de un servidor Apache, Nginx o Microsoft IIS permite consultar bases de datos como CVE para verificar la existencia de vulnerabilidades reportadas para dicha versión.

Las herramientas modernas realizan este proceso mediante el análisis de encabezados HTTP, cookies, estructuras HTML, respuestas del servidor, certificados digitales y firmas características presentes en la aplicación.

En la presente investigación, el *fingerprinting* constituye uno de los insumos principales para determinar qué procedimientos de validación establecidos por OWASP WSTG serán aplicables al portal evaluado.

Enumeración. La enumeración corresponde a la fase donde el evaluador comienza a identificar recursos específicos disponibles dentro del sistema objetivo. A diferencia del footprinting, cuyo alcance es principalmente informativo, la enumeración busca descubrir componentes concretos susceptibles de ser evaluados posteriormente durante la prueba de penetración (Scarfone et al., 2008) .

Entre las actividades habituales de enumeración se encuentran:

- Identificación de directorios y archivos accesibles.
- Descubrimiento de subdominios.
- Enumeración de servicios HTTP.
- Identificación de formularios de autenticación.
- Descubrimiento de paneles administrativos.
- Enumeración de parámetros HTTP.
- Identificación de APIs públicas.
- Descubrimiento de archivos de configuración expuestos.

La información obtenida durante esta etapa permite ampliar considerablemente la superficie de ataque conocida y facilita la identificación de puntos donde podrían existir vulnerabilidades relacionadas con autenticación, autorización, validación de entradas o exposición de información sensible.

Las herramientas automatizadas utilizadas durante una prueba de penetración incorporan diferentes mecanismos de enumeración que permiten realizar este proceso de manera rápida y sistemática.

Descubrimiento de tecnologías. El descubrimiento de tecnologías, por su parte, se enfoca en identificar el software subyacente de una aplicación web sistemas de gestión de contenido, frameworks, bibliotecas de terceros, información que orienta las pruebas posteriores hacia las vulnerabilidades conocidas de cada tecnología detectada.

1.6 Herramientas automatizadas para reconocimiento y análisis de vulnerabilidades

Existe una amplia variedad de herramientas automatizadas de código abierto orientadas al reconocimiento y a la detección preliminar de vulnerabilidades. A continuación se describen las herramientas empleadas en la presente investigación.

1.6.1 WhatWeb

WhatWeb es un escáner de identificación de tecnologías web desarrollado por Andrew Horton y Brendan Coles, que reconoce sistemas de gestión de contenido, frameworks, bibliotecas de JavaScript y otros componentes mediante el análisis de encabezados HTTP, código fuente y otros indicios (Horton & Coles, n.d.). Cuenta con más de mil ochocientos complementos (plugins) y distintos niveles de agresividad que permiten equilibrar velocidad y profundidad de detección. En esta investigación se utiliza durante el reconocimiento pasivo del portal evaluado.

1.6.2 Wappalyzer

Wappalyzer es una herramienta de identificación de tecnologías fundada en 2008 que detecta el conjunto de software utilizado por un sitio web lenguajes de programación, sistemas de gestión de contenido, plataformas de comercio electrónico, herramientas de analítica mediante el análisis de patrones públicos presentes en el código, las cabeceras y las cookies (Wappalyzer, n.d.). En esta investigación se utiliza como complemento de WhatWeb para contrastar los resultados del reconocimiento tecnológico.

1.6.3 Nikto

Nikto es un escáner de servidores web de código abierto, desarrollado originalmente por Chris Sullo y publicado en 2001, que realiza pruebas exhaustivas contra servidores web verificando miles de archivos y programas potencialmente peligrosos, versiones desactualizadas de software y configuraciones inseguras comunes (Sullo, n.d.). A diferencia de WhatWeb, Nikto está orientado específicamente a la detección de problemas de seguridad y no solo al reconocimiento.

1.6.4 Nuclei

Nuclei es un escáner de vulnerabilidades desarrollado por ProjectDiscovery que funciona mediante plantillas en formato YAML, cada una de las cuales describe un método concreto de detección para una vulnerabilidad, configuración insegura o exposición específica (ProjectDiscovery, n.d.). Su naturaleza basada en plantillas de contribución comunitaria permite incorporar rápidamente comprobaciones para vulnerabilidades recientemente divulgadas, lo que lo distingue de escáneres tradicionales de actualización más lenta.

1.6.5 Burp Suite Community

Burp Suite es una suite de pruebas de seguridad para aplicaciones web desarrollada originalmente por Dafydd Stuttard y comercializada por la empresa PortSwigger (PortSwigger, n.d.). Su edición Community incluye un proxy de intercepción que permite examinar y modificar el tráfico HTTP/HTTPS entre el navegador y el servidor, además de herramientas de repetición de solicitudes y de codificación/decodificación de datos, ampliamente utilizadas para la validación manual de hallazgos.

1.7 OWASP

Historia. El Open Worldwide Application Security Project (OWASP), inicialmente conocido como Open Web Application Security Project, fue fundado en 2001 como una comunidad abierta orientada a mejorar la seguridad del software, y se constituyó formalmente como fundación sin fines de lucro en Estados Unidos en abril de 2004 (OWASP Foundation, n.d.).

Organización. OWASP funciona como una comunidad global sostenida por voluntarios, capítulos locales y organizaciones colaboradoras, que desarrolla y mantiene proyectos, herramientas y documentos de acceso gratuito para cualquier persona interesada en la seguridad de aplicaciones (OWASP Foundation, n.d.).

Objetivos. Su objetivo principal es hacer visible la seguridad del software para que organizaciones y desarrolladores puedan tomar decisiones informadas sobre los riesgos que enfrentan sus aplicaciones. Entre sus proyectos insignia se encuentran el OWASP Top 10, el

Application Security Verification Standard (ASVS) y, de manera central para esta investigación, la OWASP Web Security Testing Guide (OWASP Foundation, n.d.).

1.8 OWASP Web Security Testing Guide (WSTG)

Qué es. La OWASP Web Security Testing Guide (WSTG) es una guía integral, de acceso libre, que documenta procedimientos técnicos para evaluar la seguridad de aplicaciones y servicios web.

Objetivos. Su objetivo es proporcionar un marco de buenas prácticas reconocido internacionalmente, utilizado tanto por evaluadores externos como por organizaciones que realizan pruebas internas, de manera que los resultados obtenidos sean comparables y reproducibles entre distintos equipos de trabajo (OWASP, 2020).

Estructura. La versión estable 4.2, publicada en diciembre de 2020, organiza su contenido en un marco introductorio sobre principios de prueba y revisión de código, seguido del núcleo metodológico dividido en doce categorías de prueba, y complementado con apéndices sobre herramientas, fuzzing e inyección codificada (OWASP, 2020).

Fases. Metodológicamente, la guía distingue entre pruebas pasivas, en las que el evaluador recopila información sin alterar el comportamiento de la aplicación, y pruebas activas, en las que se envían solicitudes específicas para verificar la presencia de cada tipo de vulnerabilidad contemplada en las doce categorías (OWASP, 2020).

Categorías de pruebas. Las doce categorías que componen la guía son: recopilación de información, configuración y gestión del despliegue, gestión de identidad, autenticación, autorización, gestión de sesiones, validación de entradas, manejo de errores, criptografía débil, lógica de negocio, pruebas del lado del cliente y pruebas de API (OWASP, 2020). Cada prueba individual recibe un identificador único con el formato WSTG-CATEGORÍA-NÚMERO, lo que facilita su referencia y trazabilidad en los reportes técnicos.

Ventajas. Entre sus principales ventajas se encuentra su carácter independiente de herramientas específicas, su amplia adopción por parte de la comunidad de ciberseguridad y su complementariedad con el OWASP Top 10: mientras este último identifica qué riesgos priorizar, la WSTG detalla cómo verificarlos técnicamente (OWASP, 2020; Abdulghaffar et al., 2023).

Limitaciones. Entre sus limitaciones se encuentra que la guía describe procedimientos y no constituye en sí misma una herramienta automatizada, por lo que su aplicación depende de la experiencia técnica de quien la ejecuta; además, su versión estable data de 2020, mientras que la versión 5.0 se encuentra todavía en desarrollo, lo que implica que algunas pruebas puedan requerir actualización frente a tecnologías más recientes (OWASP, 2020).

Este es, en efecto, el apartado más extenso del marco teórico, en la medida en que la metodología descrita constituye el eje central de todo el procedimiento de validación aplicado en esta investigación.

1.9 Validación manual de vulnerabilidades

Falsos positivos. Como se mencionó en los antecedentes de este trabajo, las herramientas automatizadas de análisis de vulnerabilidades pueden generar falsos positivos, es decir, hallazgos reportados como vulnerabilidades que, al ser examinados con mayor profundidad, no representan un riesgo real para el sistema evaluado (Abdulghaffar et al., 2023; Shahid et al., 2022).

Confirmación manual. Por esta razón, la validación manual constituye una etapa indispensable del proceso de evaluación: consiste en reproducir de forma controlada el comportamiento reportado por la herramienta automatizada, confirmando si la vulnerabilidad efectivamente existe y puede ser explotada dentro del alcance autorizado (Scarfone et al., 2008).

Evidencias. Durante esta confirmación es necesario documentar evidencias técnicas capturas de pantalla, solicitudes y respuestas HTTP, registros de las herramientas empleadas que respalden cada hallazgo validado y permitan su trazabilidad dentro del informe final (Scarfone et al., 2008).

Clasificación de hallazgos. Finalmente, cada hallazgo confirmado se clasifica según su nivel de criticidad y su relación con las categorías reconocidas por la comunidad de ciberseguridad, como las categorías del OWASP Top 10:2021 o los identificadores CWE correspondientes, lo que permite priorizar su corrección de acuerdo con el impacto potencial sobre la confidencialidad, integridad o disponibilidad del sistema evaluado (OWASP, 2021).

1.10. Conclusiones de marco teórico

El estudio de la seguridad de aplicaciones web permitió establecer que el incremento de los servicios digitales ha convertido a este tipo de plataformas en uno de los principales objetivos de ataques informáticos, haciendo indispensable la aplicación de metodologías estandarizadas que permitan identificar y validar vulnerabilidades de manera sistemática. En este contexto, la revisión bibliográfica evidenció la importancia de comprender los fundamentos de la seguridad web antes de ejecutar cualquier proceso de evaluación.

Asimismo, el análisis de los conceptos relacionados con las vulnerabilidades web, las pruebas de penetración y las fases de reconocimiento permitió comprender que la identificación de debilidades en una aplicación no depende únicamente del uso de herramientas automatizadas, sino también del conocimiento técnico del evaluador y de la correcta interpretación de los resultados obtenidos. En este sentido, las etapas de

footprinting, *fingerprinting* y enumeración constituyen actividades esenciales para conocer la superficie de ataque y orientar adecuadamente el proceso de evaluación.

Finalmente, el marco teórico permitió fundamentar la elección de la metodología **OWASP Web Security Testing Guide (WSTG)** como referencia para la validación de vulnerabilidades identificadas durante la investigación. Esta metodología proporciona procedimientos estandarizados y ampliamente reconocidos por la comunidad internacional de ciberseguridad, permitiendo verificar la existencia real de los hallazgos obtenidos mediante herramientas automatizadas y garantizando que los resultados finales se encuentren sustentados en buenas prácticas de evaluación de seguridad.

Capítulo II

DIAGNÓSTICO DEL SISTEMA Y AMENAZAS

2.1 Introducción capitular

El presente capítulo describe y analiza la situación actual del Portal Web del Servicio de Impuestos Nacionales de Bolivia, en función de los objetivos planteados en el capítulo anterior. A partir de la información obtenida mediante herramientas de reconocimiento pasivo y activo, se identifican las fortalezas, debilidades y vulnerabilidades del portal, con el propósito de sustentar la necesidad de aplicar la metodología OWASP Web Security Testing Guide (WSTG) para la validación de los hallazgos detectados.

El diagnóstico se organiza en torno a las herramientas descritas en el marco teórico WhatWeb, Wappalyzer, Nikto y Nuclei, presentando de forma ordenada los resultados obtenidos durante la fase de reconocimiento, antes de proceder a su validación manual en capítulos posteriores.

2.2 Metodología del diagnóstico

El diagnóstico del Portal Web del Servicio de Impuestos Nacionales de Bolivia se desarrolló siguiendo un enfoque de pruebas de penetración de caja negra (Black Box Testing), simulando la perspectiva de un usuario externo sin acceso privilegiado a la infraestructura tecnológica del sistema. Bajo este enfoque, únicamente se utilizaron técnicas de reconocimiento e identificación de posibles vulnerabilidades accesibles desde Internet, respetando en todo momento los principios éticos de una evaluación de seguridad defensiva.

Las actividades realizadas corresponden a la fase de Information Gathering y Configuration and Deployment Management Testing descritas por la **OWASP Web Security Testing Guide (WSTG)**, evitando la ejecución de pruebas de explotación o cualquier acción que pudiera afectar la disponibilidad, integridad o confidencialidad de los servicios proporcionados por el portal institucional.

El reconocimiento fue realizado el **15 de julio de 2026** sobre el dominio <https://impuestos.gob.bo>, utilizando un entorno de pruebas basado en Kali Linux y herramientas ampliamente reconocidas dentro del ámbito de la ciberseguridad. Las principales herramientas empleadas fueron WhatWeb para la identificación tecnológica, Wappalyzer para el análisis de componentes web, Nikto 2.6.0 para el reconocimiento automatizado de configuraciones inseguras y Nuclei 3.8.0 para la identificación preliminar de posibles vulnerabilidades mediante plantillas automatizadas.

Los resultados obtenidos constituyen un diagnóstico inicial del estado de seguridad del portal y servirán como base para la validación manual de los hallazgos utilizando la metodología **OWASP Web Security Testing Guide**, desarrollada en los capítulos posteriores de la presente investigación.

2.3 Identificación del objetivo

El objeto de estudio de la presente investigación corresponde al Portal Web del Servicio de Impuestos Nacionales (SIN) de Bolivia, disponible públicamente a través del dominio oficial www.impuestos.gob.bo. Este portal constituye el principal medio de interacción electrónica entre la Administración Tributaria y los contribuyentes, ofreciendo información institucional, normativa tributaria y diversos servicios digitales relacionados con el cumplimiento de obligaciones fiscales.

Entre los principales servicios disponibles se encuentran el acceso a la Oficina Virtual, el Sistema Integrado de Administración Tributaria (SIAT en Línea), consultas tributarias, descarga de formularios, emisión de facturas electrónicas, verificaciones, normativa vigente y otros servicios orientados tanto a personas naturales como jurídicas. Debido a que estos servicios procesan información tributaria y datos potencialmente sensibles, resulta indispensable que la plataforma mantenga adecuados controles de seguridad que garanticen la confidencialidad, integridad y disponibilidad de la información.

En el marco de esta investigación, el alcance del diagnóstico se limita exclusivamente a los servicios accesibles públicamente desde Internet, adoptando un enfoque de caja negra. En consecuencia, no se realizaron actividades de autenticación privilegiada, explotación de vulnerabilidades ni acciones que pudieran afectar la operación normal del portal, respetando en todo momento los principios éticos de una evaluación de seguridad defensiva.

Figura 2.1 *Página principal del Portal Web del Servicio de Impuestos Nacionales de Bolivia*



2.4 Identificación de tecnologías (WhatWeb y Wappalyzer)

2.4.1 WhatWeb

Se ejecutó:

```
whatweb -v https://impuestos.gob.bo
```

Figura 2.2. Resultado obtenido mediante WhatWeb.

```
(kali㉿kali)-[~]
$ whatweb -v https://impuestos.gob.bo
WhatWeb report for https://impuestos.gob.bo
Status      : 500 Internal Server Error
Title       : The URL you requested has been blocked
IP          : <Unknown>
Country     : <Unknown>
Summary     :
Detected Plugins:
HTTP Headers:
  HTTP/1.1 500 Internal Server Error
  Content-Length: 39112
  Content-Type: text/html
```

La herramienta WhatWeb no logró completar el reconocimiento tecnológico del portal debido a que el servidor respondió con un código **HTTP 500 (Internal Server Error)** acompañado del mensaje *The URL you requested has been blocked*. Este comportamiento sugiere la existencia de mecanismos de protección capaces de detectar y restringir solicitudes generadas por herramientas automatizadas de reconocimiento.

Desde el punto de vista de la seguridad, esta respuesta puede interpretarse como una medida destinada a reducir la recopilación automatizada de información sobre la infraestructura tecnológica del portal, dificultando el reconocimiento inicial por parte de posibles atacantes.

No obstante, este resultado también evidencia una limitación de determinadas herramientas automatizadas frente a mecanismos modernos de protección implementados en aplicaciones web.

2.4.2 Wappalyzer

Figura 2.3. Tecnologías identificadas mediante Wappalyzer.

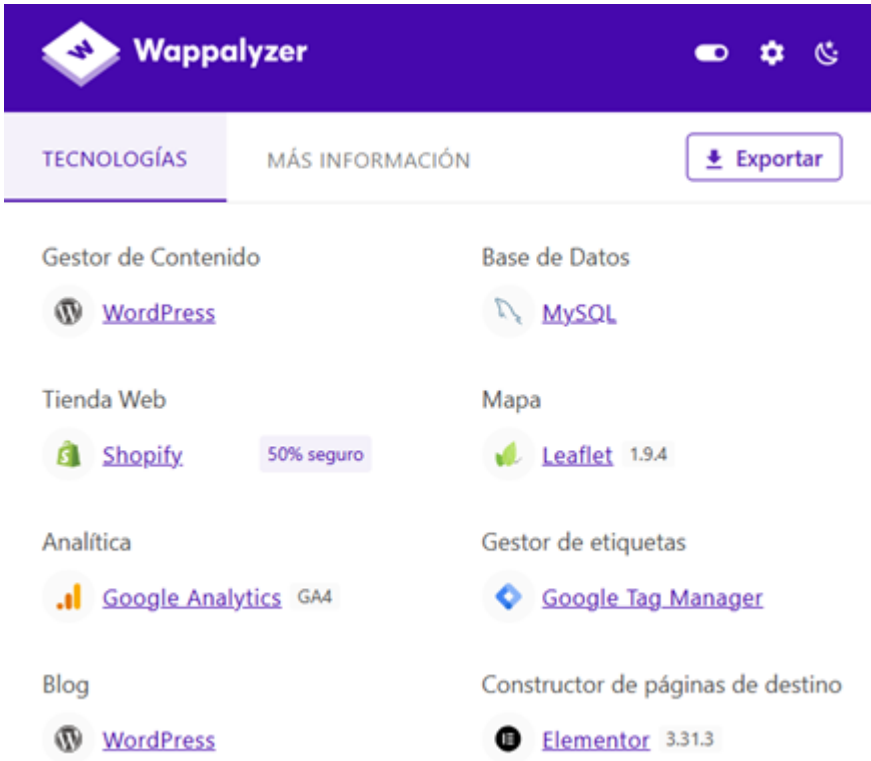


Tabla 2.1. Tecnologías identificadas mediante Wappalyzer

Categoría	Tecnología
Servidor	Apache HTTP Server
CMS	WordPress
Lenguaje	PHP
Base de datos	MySQL
SO	Ubuntu
Framework UI	Bootstrap
Plugins	Elementor
Plugins	Contact Form 7
Analítica	Google Analytics
Tag Manager	Google Tag Manager

Bibliotecas	jQuery
Infraestructura	AWS

El reconocimiento tecnológico permitió identificar que el portal se encuentra desarrollado sobre un entorno basado en **Apache HTTP Server**, utilizando **PHP** como lenguaje de programación y **MySQL** como sistema gestor de bases de datos, componentes ampliamente utilizados dentro del desarrollo de aplicaciones web.

Asimismo, Wappalyzer identificó el uso de **WordPress** como gestor de contenidos, junto con los complementos **Elementor** y **Contact Form 7**, elementos que representan componentes de terceros cuya seguridad depende del mantenimiento y actualización continua por parte de los administradores del sitio.

También se observó la utilización de servicios externos como Google Analytics, Google Tag Manager y Amazon Web Services (AWS), evidenciando la integración del portal con plataformas ampliamente utilizadas para analítica, distribución de contenido e infraestructura tecnológica.

La identificación de estas tecnologías resulta relevante debido a que permitirá seleccionar posteriormente las pruebas específicas contempladas por OWASP WSTG para cada componente detectado.

2.5 Análisis preliminar de vulnerabilidades (Nikto y Nuclei)

2.5.1 Resultados obtenidos con Nikto

Como parte del diagnóstico se ejecutó el siguiente comando:

```
nikto -h https://impuestos.gob.bo -o nikto_sin.txt -Format txt
```

Nikto permitió identificar diversas configuraciones relacionadas con el servidor web, certificados digitales y cabeceras HTTP de seguridad.

Figura 2.4. Resultado del análisis automatizado realizado mediante Nikto.

```

$ nikto -h https://impuestos.gob.bo -o nikto_sin.txt -Format txt
- Nikto v2.6.0

+ Target IP: 170.82.244.41
+ Target Hostname: impuestos.gob.bo
+ Target Port: 443

+ SSL Info: Subject: /CN=*.impuestos.gob.bo
            CN: *.impuestos.gob.bo
            SAN: *.impuestos.gob.bo, impuestos.gob.bo
            Ciphers: ECDHE-RSA-AES256-GCM-SHA384
            Issuer: /C=US/O=DigiCert Inc/OU=www.digicert.com/CN=R
apidSSL TLS RSA CA G1
+ Platform: Linux/Unix
+ Start Time: 2026-07-16 11:26:42 (GMT-4)

+ Server: Apache/2.4.52 (Ubuntu)
+ ERROR: Failed to check for updates: 403
+ [999100] /: Uncommon header(s) 'x-redirect-by' found, with contents: WordPr
ess.
+ [999961] /: Cookie cookiesession1 created without the secure flag. See: htt
ps://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies
+ No CGI Directories found (use '-C all' to force check all possible dirs). C
GI tests skipped.
+ [000427] /: Link header(s) found with value(s): <https://www.impuestos.gob.

```

Tabla 2.2. Hallazgos identificados mediante Nikto

Código	Hallazgo	Estado
N-01	Servidor Apache 2.4.52 (Ubuntu)	Información recopilada
N-02	Uso de certificado TLS comodín (*.impuestos.gob.bo)	Información recopilada
N-03	Cookie cookiesession1 sin atributo Secure	Posible vulnerabilidad
N-04	Cabecera Referrer-Policy ausente	Posible vulnerabilidad
N-05	Cabecera Strict-Transport-Security ausente	Posible vulnerabilidad
N-06	Cabecera Permissions-Policy ausente	Posible vulnerabilidad
N-07	Cabecera X-Content-Type-Options ausente	Posible vulnerabilidad
N-08	Cabecera Content-Security-Policy ausente	Posible vulnerabilidad
N-09	Exposición del endpoint wp-json	Información recopilada
N-10	Cabecera X-Redirect-By: WordPress	Información recopilada

El análisis automatizado permitió identificar que el servidor web utiliza **Apache 2.4.52 sobre Ubuntu**, información que coincide con las tecnologías previamente detectadas mediante Wappalyzer. La identificación del software utilizado no constituye por sí misma una vulnerabilidad; sin embargo, representa información útil para un posible atacante al permitir orientar futuras técnicas de reconocimiento o búsqueda de vulnerabilidades específicas asociadas a dichas tecnologías.

Asimismo, Nikto detectó que la aplicación utiliza un **certificado digital comodín (Wildcard Certificate)** para el dominio *.impuestos.gob.bo. Este tipo de certificados permite proteger múltiples subdominios mediante un único certificado TLS y constituye una práctica común en infraestructuras institucionales, por lo que su presencia no representa un riesgo de seguridad por sí misma.

Uno de los hallazgos más relevantes corresponde a la creación de la cookie denominada **cookiesession1** sin el atributo **Secure**. La ausencia de este atributo puede permitir que la cookie sea transmitida mediante conexiones no cifradas si el servidor aceptara solicitudes HTTP, incrementando el riesgo de exposición de información asociada a la sesión del usuario. No obstante, será necesario verificar este comportamiento mediante pruebas manuales antes de confirmar la existencia de una vulnerabilidad.

Nikto también reportó la ausencia de varias cabeceras HTTP de seguridad, entre ellas **Strict-Transport-Security, Content-Security-Policy, Referrer-Policy, Permissions-Policy** y **X-Content-Type-Options**. Estas cabeceras constituyen mecanismos adicionales de protección frente a diversos ataques, como *Clickjacking*, *Cross-Site Scripting (XSS)*, *MIME Sniffing* o fugas de información mediante cabeceras HTTP. Sin embargo, la ausencia reportada por una herramienta automatizada no implica necesariamente una configuración insegura, debido a que algunas cabeceras pueden implementarse únicamente sobre determinados recursos o respuestas HTTP específicas.

Finalmente, se identificó la presencia del endpoint **wp-json** y la cabecera **X-Redirect-By: WordPress**, confirmando nuevamente la utilización de WordPress como gestor de contenidos. Aunque estos elementos forman parte del funcionamiento normal del CMS, también proporcionan información adicional sobre la tecnología empleada por la aplicación.

2.5.2 Resultados obtenidos con Nuclei

Con el objetivo de complementar el análisis realizado mediante Nikto, se utilizó la herramienta **Nuclei**, la cual permite ejecutar miles de plantillas de detección basadas en firmas conocidas para identificar configuraciones inseguras, tecnologías expuestas y posibles vulnerabilidades.

Se ejecutó el siguiente comando:

```
nuclei -u https://impuestos.gob.bo -severity info,low -o nuclei_sin.txt
```


NU-07	Tenant Microsoft Azure identificado	Informativa
NU-08	Certificados y registros TXT detectados	Informativa

A diferencia de Nikto, la mayoría de los resultados obtenidos mediante Nuclei corresponden a información relacionada con la infraestructura del dominio y la configuración de sus servicios DNS. Entre los hallazgos positivos destaca la correcta implementación de políticas **SPF** y **DMARC**, mecanismos destinados a reducir ataques de suplantación de identidad (*Email Spoofing*) mediante la validación de correos electrónicos enviados desde el dominio institucional.

De igual manera, Nuclei identificó correctamente los servidores DNS autoritativos, registros MX y diversos registros TXT utilizados para la validación de servicios externos, como Microsoft, Google y Cisco. Estos elementos reflejan la integración del portal con diferentes plataformas tecnológicas y no representan vulnerabilidades de seguridad por sí mismos.

Coincidiendo con los resultados obtenidos mediante Nikto, Nuclei detectó nuevamente la existencia de una cookie sin el atributo **Secure**, incrementando el nivel de confianza sobre este hallazgo y justificando su posterior validación mediante pruebas manuales.

Finalmente, la identificación de un tenant asociado a Microsoft Azure evidencia la utilización de servicios de autenticación o integración con plataformas en la nube, información que puede resultar útil durante la fase de reconocimiento de una prueba de penetración, aunque no constituye una vulnerabilidad confirmada.

2.6 Fortalezas identificadas

A partir de la información obtenida durante la fase de reconocimiento y del análisis realizado mediante las herramientas automatizadas empleadas, fue posible identificar diversos aspectos que evidencian la implementación de controles de seguridad en el Portal Web del Servicio de Impuestos Nacionales. Si bien estas características no garantizan la ausencia de vulnerabilidades, representan buenas prácticas que contribuyen a reducir la superficie de ataque expuesta a usuarios externos.

2.6.1 Uso de comunicaciones cifradas mediante HTTPS

El portal utiliza el protocolo HTTPS como mecanismo principal para el intercambio de información entre los usuarios y el servidor, empleando un certificado digital emitido por DigiCert mediante un certificado comodín (*.impuestos.gob.bo). Esta configuración permite proteger múltiples subdominios bajo un mismo certificado y garantiza el cifrado de la información transmitida durante las sesiones de comunicación.

La utilización de HTTPS constituye uno de los controles fundamentales para proteger la confidencialidad e integridad de los datos intercambiados entre el cliente y el servidor, reduciendo el riesgo de ataques de interceptación de información (*Man-in-the-Middle*).

2.6.2 Implementación de mecanismos de protección frente al reconocimiento automatizado

Durante la ejecución de WhatWeb el servidor respondió con un código HTTP 500 acompañado del mensaje *The URL you requested has been blocked*, impidiendo la identificación automática de las tecnologías utilizadas por la aplicación.

Este comportamiento evidencia la existencia de mecanismos destinados a limitar la recopilación automatizada de información por parte de herramientas de reconocimiento, dificultando la fase inicial de enumeración utilizada comúnmente durante pruebas de penetración.

2.6.3 Configuración de políticas de autenticación del correo electrónico

El análisis realizado mediante Nuclei permitió identificar la implementación de registros DNS correspondientes a las políticas **SPF** y **DMARC**, utilizadas para validar el origen de los mensajes enviados desde el dominio institucional.

La presencia de estas políticas constituye una buena práctica de seguridad, ya que reduce la posibilidad de ataques de suplantación de identidad (*Email Spoofing*) y fortalece la protección de los servicios de correo electrónico asociados al dominio.

2.6.4 Consistencia tecnológica de la infraestructura

Las tecnologías identificadas mediante Wappalyzer fueron corroboradas posteriormente por Nikto, observándose consistencia entre ambas herramientas respecto al uso de Apache HTTP Server, Ubuntu, PHP y WordPress.

La coincidencia entre diferentes herramientas incrementa la confiabilidad del diagnóstico obtenido y proporciona una base sólida para la fase posterior de validación de vulnerabilidades.

Tabla 2.4. Fortalezas identificadas

Fortalezas	Evidencia
Uso de HTTPS y certificado TLS válido	Nikto
Certificado comodín (*.impuestos.gob.bo)	Nikto
Implementación de SPF y DMARC	Nuclei

Protección frente al reconocimiento automatizado	WhatWeb
Consistencia entre tecnologías detectadas	Wappalyzer y Nikto

2.7 Debilidades y problemáticas identificadas

Durante la ejecución de las herramientas automatizadas también se identificaron diversos hallazgos relacionados con configuraciones de seguridad que podrían representar debilidades dentro del portal evaluado. No obstante, de acuerdo con la metodología propuesta en esta investigación, dichos resultados corresponden únicamente a **hallazgos preliminares** y deberán ser verificados manualmente mediante las pruebas definidas por la **OWASP Web Security Testing Guide**, con el propósito de confirmar o descartar su impacto sobre la seguridad de la aplicación.

2.7.1 Ausencia de cabeceras HTTP de seguridad

Nikto reportó la ausencia de diversas cabeceras HTTP recomendadas para fortalecer la seguridad de aplicaciones web, entre ellas **Strict-Transport-Security**, **Content-Security-Policy**, **Referrer-Policy**, **Permissions-Policy** y **X-Content-Type-Options**.

La ausencia de estas cabeceras podría facilitar determinados escenarios de ataque relacionados con *Cross-Site Scripting (XSS)*, *Clickjacking*, *MIME Sniffing* y divulgación de información. Sin embargo, será necesario validar manualmente si dichas cabeceras realmente se encuentran ausentes en todos los recursos del portal o únicamente en determinadas respuestas HTTP.

2.7.2 Cookie sin atributo Secure

Tanto Nikto como Nuclei identificaron que la cookie denominada **cookiesession1** aparentemente no incorpora el atributo **Secure**.

La coincidencia de este hallazgo en dos herramientas independientes incrementa el nivel de confianza sobre el resultado obtenido; sin embargo, será necesario comprobar manualmente el comportamiento real de la aplicación para determinar si la cookie puede transmitirse mediante conexiones inseguras o si existen controles adicionales implementados por el servidor.

2.7.3 Divulgación de información tecnológica

El análisis permitió identificar diversos elementos que revelan información sobre la tecnología utilizada por el portal, incluyendo la presencia de WordPress, Apache HTTP Server, Ubuntu, PHP, el endpoint **wp-json** y la cabecera **X-Redirect-By**.

Aunque esta información no constituye una vulnerabilidad por sí misma, incrementa la cantidad de información disponible para un posible atacante durante la fase de reconocimiento, facilitando la búsqueda de vulnerabilidades específicas asociadas a dichas tecnologías.

Tabla 2.5. Hallazgos que requieren validación

Hallazgo	Herramienta	Estado
Cookie sin atributo Secure	Nikto / Nuclei	Requiere validación
Ausencia de HSTS	Nikto	Requiere validación
Ausencia de CSP	Nikto	Requiere validación
Ausencia de X-Content-Type-Options	Nikto	Requiere validación
Ausencia de Referrer-Policy	Nikto	Requiere validación
Ausencia de Permissions-Policy	Nikto	Requiere validación
Exposición de tecnologías	Wappalyzer / Nikto	Requiere análisis

2.8 Conclusiones capitulares

El diagnóstico realizado sobre el Portal Web del Servicio de Impuestos Nacionales de Bolivia permitió obtener una visión general de la infraestructura, tecnologías implementadas y configuraciones de seguridad expuestas públicamente, empleando un conjunto de herramientas automatizadas de reconocimiento y análisis de vulnerabilidades. La información recopilada constituye una línea base para comprender el estado actual de seguridad del portal sin realizar acciones de explotación o acceso privilegiado, manteniendo un enfoque de pruebas de penetración de caja negra.

Los resultados obtenidos evidenciaron que el portal implementa diversos controles de seguridad, entre los que destacan el uso de comunicaciones cifradas mediante HTTPS, la utilización de un certificado digital válido, la configuración de políticas de autenticación de correo electrónico (SPF y DMARC) y la existencia de mecanismos destinados a dificultar el reconocimiento automatizado de la infraestructura. Estos elementos reflejan la adopción de buenas prácticas orientadas a fortalecer la seguridad de los servicios publicados.

No obstante, las herramientas automatizadas también identificaron diversos hallazgos relacionados con posibles debilidades de configuración, entre ellas la aparente ausencia de cabeceras HTTP de seguridad, la detección de una cookie sin el atributo **Secure**, la exposición de información tecnológica del servidor. Debido a la naturaleza automatizada de las herramientas empleadas, estos resultados no pueden considerarse evidencia suficiente para confirmar la existencia de vulnerabilidades, ya que podrían corresponder a falsos positivos o requerir un análisis contextual más profundo.

Asimismo, la correlación de resultados obtenidos mediante Wappalyzer, Nikto y Nuclei permitió incrementar el nivel de confianza sobre determinados hallazgos, especialmente aquellos detectados por más de una herramienta, como la identificación del gestor de contenidos WordPress y la ausencia del atributo **Secure** en la cookie de sesión. Esta correlación demuestra la importancia de utilizar múltiples herramientas durante la fase de reconocimiento para obtener un diagnóstico más completo y confiable.

Finalmente, los hallazgos identificados durante este capítulo justifican la necesidad de aplicar un proceso de validación manual basado en la metodología **OWASP Web Security Testing Guide (WSTG)**. En consecuencia, el capítulo siguiente estará orientado a verificar cada uno de los hallazgos obtenidos mediante herramientas automatizadas, con el propósito de determinar cuáles corresponden efectivamente a vulnerabilidades de seguridad y cuáles pueden descartarse como resultados no concluyentes o falsos positivos.

Capítulo III

PROPUESTA

3.1 Introducción

El diagnóstico desarrollado en el Capítulo II identificó una serie de hallazgos preliminares mediante herramientas automatizadas de reconocimiento y análisis de vulnerabilidades (WhatWeb, Wappalyzer, Nikto y Nuclei), entre los que se incluyen la ausencia de cabeceras HTTP de seguridad, una posible debilidad en la configuración de la cookie de sesión y la divulgación de información tecnológica. Sin embargo, tal como se estableció en el marco teórico, los resultados obtenidos mediante herramientas automatizadas pueden contener falsos positivos, por lo que no constituyen por sí solos evidencia suficiente para afirmar la existencia de una vulnerabilidad (Abdulhaffar et al., 2023).

El presente capítulo desarrolla la propuesta de la investigación, la cual consiste en validar manualmente cada uno de los hallazgos preliminares identificados en el diagnóstico,

aplicando los procedimientos de comprobación establecidos por la metodología OWASP Web Security Testing Guide (WSTG) mediante el uso de Burp Suite Community y herramientas complementarias de inspección manual. Como resultado de este proceso, cada hallazgo se clasifica como confirmado o como falso positivo, y para los hallazgos confirmados se documenta la recomendación técnica de remediación correspondiente.

De esta manera, la propuesta responde directamente a la problemática identificada en el Capítulo II: la necesidad de determinar, con criterio técnico y trazabilidad metodológica, cuáles de las debilidades detectadas de forma automatizada representan un riesgo real para el Portal Web del Servicio de Impuestos Nacionales de Bolivia.

3.2 Descripción general

Descripción general. La propuesta consiste en un proceso de validación manual de vulnerabilidades, estructurado en cuatro líneas de comprobación, correspondientes a los cuatro grupos de hallazgos identificados durante el diagnóstico: (1) configuración de cabeceras de seguridad HTTP, (2) gestión de sesiones y atributos de cookies, (3) divulgación de información tecnológica, y (4) exposición de servicios de red.

Para cada línea de comprobación se sigue el mismo procedimiento general: (a) se retoma el hallazgo reportado por la herramienta automatizada correspondiente; (b) se ejecuta una verificación manual utilizando Burp Suite Community, las herramientas de desarrollo del navegador, u otras técnicas de inspección directa, en concordancia con los casos de prueba de la metodología OWASP WSTG; (c) se determina si el hallazgo corresponde a una vulnerabilidad confirmada o a un falso positivo; y (d) en caso de confirmarse, se documenta una recomendación técnica orientada a su corrección.

Este enfoque no contempla la explotación activa de las vulnerabilidades identificadas, en concordancia con el alcance de caja negra definido en el Capítulo I y con los principios éticos que rigen la presente investigación, la cual se limita a actividades de reconocimiento y validación no intrusiva sobre el portal evaluado.

3.3 Ejecución de los casos de prueba

3.3.1 WSTG-INFO-02 Divulgación de la versión del servidor web

Como parte del reconocimiento automatizado, Nikto identificó que el servidor responde con la cabecera Server: Apache/2.4.52 (Ubuntu) en todas las respuestas HTTP (hallazgo N-01, apartado 2.5.1), información que además coincidió con la tecnología de servidor detectada por Wappalyzer (Tabla 2.1). Este caso de prueba corresponde a WSTG-INFO-02 y busca

determinar si el servidor expone de forma innecesaria detalles precisos de su versión, información que puede orientar a un atacante hacia vulnerabilidades conocidas asociadas a dicha versión específica (OWASP, 2020).

La validación manual se realizó inspeccionando directamente las cabeceras de respuesta mediante Burp Suite Community (Figura 3.1) y mediante solicitudes HTTP directas con curl (Figura 3.4), en ambos casos sobre distintos recursos del portal. En todas las respuestas analizadas la cabecera Server mantuvo el mismo valor, Apache/2.4.52 (Ubuntu), sin evidencia de que el servidor oculte o generalice esta información (por ejemplo, mediante la directiva ServerTokens de Apache).

En consecuencia, el caso de prueba WSTG-INFO-02 se considera confirmado: el servidor divulga de forma consistente la versión exacta del software y del sistema operativo subyacente, lo que constituye una debilidad de configuración de bajo impacto individual, pero que reduce el esfuerzo de reconocimiento necesario para un atacante.

3.3.2 WSTG-INFO-08 Divulgación de tecnologías y framework de aplicación

El reconocimiento con Wappalyzer (Tabla 2.1, apartado 2.4) identificó como preliminar el uso de WordPress como gestor de contenidos, PHP como lenguaje de programación, MySQL como sistema gestor de bases de datos, y los complementos Elementor y Contact Form 7, entre otras tecnologías. Nikto corroboró de forma independiente el uso de WordPress mediante la cabecera X-Redirect-By: WordPress y la presencia del endpoint wp-json (hallazgos N-09 y N-10, apartado 2.5.1). Este caso de prueba corresponde a WSTG-INFO-08 y busca determinar si dicha información tecnológica es verificable de forma directa sobre el servidor, más allá de la huella digital inferida por herramientas automatizadas de terceros (OWASP, 2020).

La validación se realizó inspeccionando manualmente las cabeceras y el contenido de las respuestas HTTP mediante Burp Suite Community (Figura 3.1) y mediante solicitudes directas con curl (Figura 3.4). Se confirmó la presencia de la cabecera X-Redirect-By: WordPress y del enlace de autodescubrimiento de la API REST (Link: <https://www.impuestos.gob.bo/index.php/wp-json/>; rel="https://api.w.org/"), ambos generados de forma nativa por el núcleo de WordPress y visibles sin necesidad de autenticación.

En consecuencia, el caso de prueba WSTG-INFO-08 se considera confirmado: el propio servidor expone, sin intervención de herramientas de huella digital externas, indicadores directos del gestor de contenidos y del framework de aplicación utilizados, corroborando de forma independiente los hallazgos preliminares de Wappalyzer.

3.3.3 WSTG-CONF-02 Exposición del endpoint de la API REST (wp-json)

Nikto identificó como hallazgo preliminar la exposición del endpoint wp-json (hallazgo N-09, apartado 2.5.1), correspondiente a la API REST nativa de WordPress. Este caso de prueba corresponde a WSTG-CONF-02 y busca determinar el alcance de la información accesible a través de dicho endpoint sin autenticación (OWASP, 2020).

La validación se realizó mediante solicitudes HTTP directas al portal (Figura 3.4), confirmando que el servidor anuncia activamente la ubicación de la API REST mediante la cabecera Link (<https://www.impuestos.gob.bo/index.php/wp-json/>; rel="https://api.w.org/") en toda respuesta HTTP, incluso ante solicitudes con métodos no habituales como OPTIONS. El acceso al índice de la API REST permite, sin autenticación, enumerar las rutas y espacios de nombres (namespaces) registrados por el núcleo de WordPress y por los complementos instalados, lo que amplía la información disponible sobre la composición interna del sitio más allá de lo detectado por Wappalyzer.

No obstante, el alcance no intrusivo definido para la presente investigación no contempló solicitar rutas específicas de mayor sensibilidad dentro de la API, como wp-json/wp/v2/users, comúnmente utilizada para enumerar nombres de usuario registrados en instalaciones de WordPress, por lo que no fue posible determinar si dicha enumeración es factible en el portal evaluado. En consecuencia, el caso de prueba WSTG-CONF-02 se considera parcialmente confirmado: se confirma la exposición pública del índice de la API REST y de la información de complementos que este revela, pero no se determinó el alcance de exposición de datos más sensibles, como la eventual enumeración de usuarios.

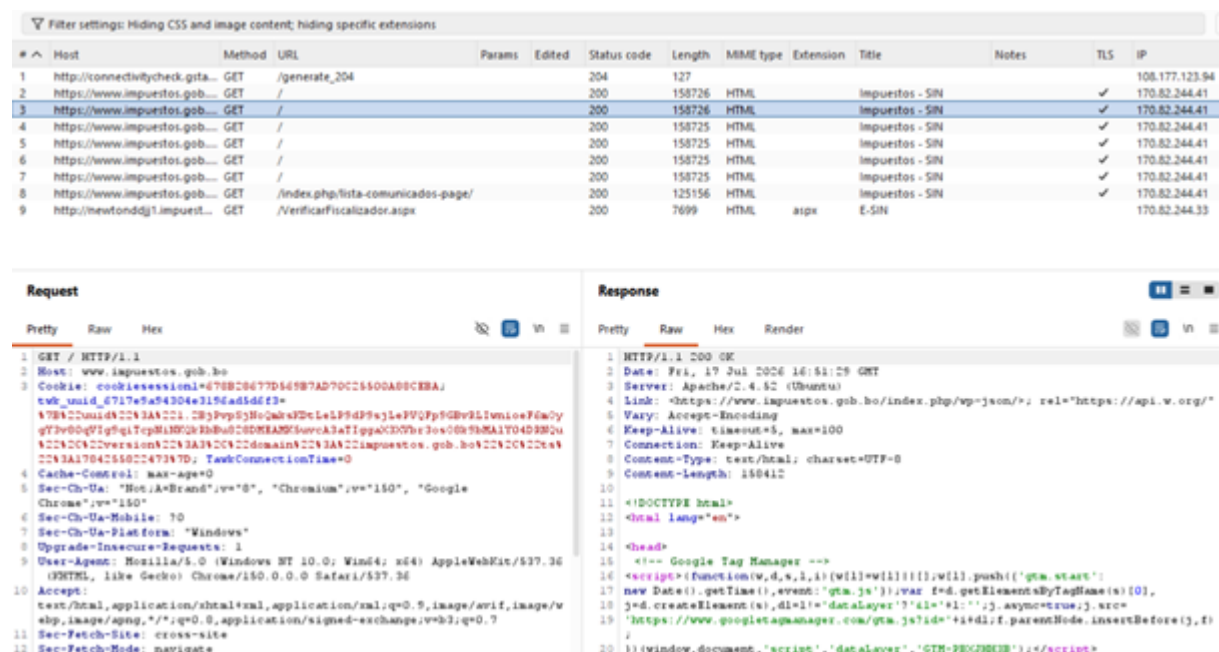
3.3.4 WSTG-CONF-07 / WSTG-CONF-14 Validación de cabeceras HTTP de seguridad

El primer proceso de validación manual se realizó sobre los hallazgos relacionados con la configuración de seguridad HTTP identificados durante la fase de reconocimiento automatizado. Para ello se utilizó Burp Suite Community como proxy de interceptación, permitiendo inspeccionar en detalle las solicitudes y respuestas HTTP intercambiadas entre el navegador y el portal web del Servicio de Impuestos Nacionales.

La validación se desarrolló siguiendo las recomendaciones establecidas por la metodología **OWASP Web Security Testing Guide (WSTG)**, específicamente en las actividades correspondientes a la revisión de configuraciones de seguridad del protocolo HTTP. El objetivo consistió en determinar si los resultados obtenidos mediante Nikto correspondían efectivamente a debilidades presentes en el servidor o si se trataba de falsos positivos derivados del proceso automatizado de reconocimiento.

Durante la inspección manual de las respuestas HTTP se verificó la ausencia de varias cabeceras de seguridad recomendadas por OWASP, entre ellas **Strict-Transport-Security (HSTS)**, **Content-Security-Policy (CSP)**, **X-Content-Type-Options**, **Permissions-Policy** y **Referrer-Policy**. La revisión realizada en Burp Suite confirmó que dichas cabeceras no fueron enviadas por el servidor web durante las respuestas analizadas, corroborando los hallazgos obtenidos previamente con Nikto.

Figura 3.1. Validación manual de las cabeceras HTTP del portal web mediante Burp Suite Community.



3.3.5 WSTG-SESS-02 Validación de atributos de cookies de sesión

Como parte del reconocimiento automatizado, las herramientas Nikto y Nuclei identificaron como posible hallazgo de seguridad la existencia de la cookie denominada **cookiesession1** sin el atributo **Secure**, indicando que dicha cookie podría transmitirse mediante conexiones HTTP no cifradas.

Con el propósito de verificar este resultado, se realizó una inspección manual utilizando las herramientas de desarrollo del navegador Google Chrome y Burp Suite Community. Durante la revisión se analizaron las cookies establecidas por el servidor, verificando individualmente los atributos asociados a cada una de ellas.

La inspección inicial mediante las herramientas de desarrollo de Google Chrome sugería que la cookie **cookiesession1** contaba con el atributo **Secure** habilitado. Sin embargo, la verificación complementaria descrita en el apartado 3.3.9 mediante Security Headers y Mozilla HTTP Observatory arrojó un resultado contrario, por lo que se realizó una segunda

inspección manual, esta vez mediante Burp Suite Community, interceptando directamente la cabecera Set-Cookie enviada por el servidor. Dicha inspección confirmó que el atributo Secure no se encuentra presente en la cookie de sesión, por lo que esta puede ser transmitida, en determinadas circunstancias, mediante conexiones HTTP no cifradas.

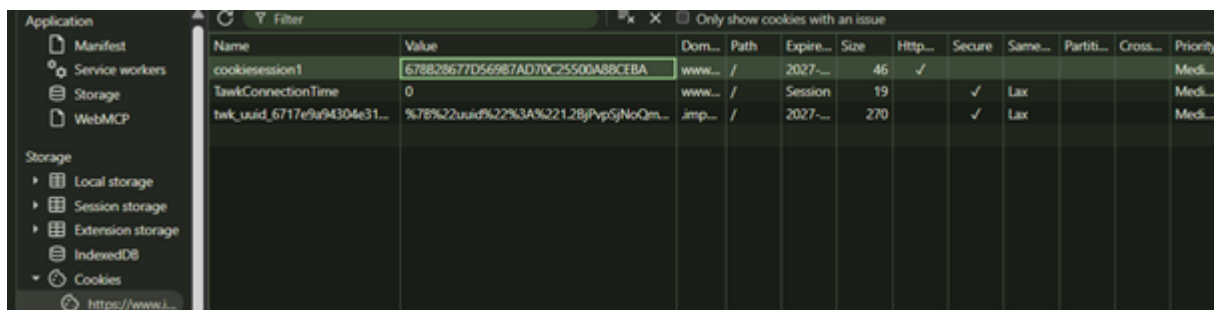
En consecuencia, el hallazgo reportado inicialmente por Nikto y Nuclei se considera confirmado. Este resultado ilustra, además, la importancia de contrastar más de una técnica de validación antes de descartar un hallazgo: una primera inspección manual, tomada de forma aislada, hubiera llevado a una conclusión errónea.

Este proceso constituye uno de los principales aportes de la presente investigación, ya que evidencia que ni los resultados generados automáticamente ni una única técnica de validación manual deben asumirse como concluyentes sin contrastarlos con procedimientos adicionales.

Tabla 3.1. Resultado de la validación manual de la cookie de sesión

Hallazgo automatizado	Herramienta	Validación manual	Resultado
Cookie cookiesession1 sin atributo Secure	Nikto	Inspección mediante Chrome DevTools y Burp Suite	confirmado
Cookie cookiesession1 sin atributo Secure	Nuclei	Inspección mediante Chrome DevTools y Burp Suite	confirmado

Figura 3.2. Verificación manual de los atributos de la cookie cookiesession1 mediante las herramientas de desarrollo de Google Chrome.



Name	Value	Dom...	Path	Expire...	Size	Http...	Secure	Same...	Partiti...	Cross...	Priority
cookiesession1	678828677D56987AD70C25500A88CEBA	www...	/	2027-...	46	✓	✓	Same...			Medi...
TaskConnectionTime	0	www...	/	Session	19		✓	Lax			Medi...
twik_uid_6717e9a94304e31...	%7B%22uid%22%3A%221.28jPvp5jNoQm...	imp...	/	2027-...	270		✓	Lax			Medi...

3.3.6 WSTG-CRYP-01 Configuración de seguridad de la capa de transporte (TLS)

Este caso de prueba busca verificar la configuración del cifrado utilizado por el servidor, evaluando si se aceptan protocolos y versiones de TLS/SSL obsoletos que puedan comprometer la confidencialidad de las comunicaciones (OWASP, 2020). El hallazgo preliminar proviene de Nikto, que identificó el uso de un certificado digital válido emitido por DigiCert, documentado como fortaleza en el apartado 2.6.1 del Capítulo II; sin embargo, dicho hallazgo no verificaba qué versiones del protocolo acepta el servidor.

La validación se realizó forzando manualmente el establecimiento de conexiones TLS bajo distintas versiones del protocolo mediante OpenSSL. Al forzar TLS 1.2, la conexión se estableció correctamente utilizando el conjunto de cifrado ECDHE-RSA-AES256-GCM-SHA384, considerado seguro. Sin embargo, al forzar TLS 1.0 protocolo declarado obsoleto por la industria desde 2018 debido a debilidades criptográficas conocidas, el servidor también aceptó la conexión, negociando el conjunto de cifrado ECDHE-RSA-AES256-SHA. El intento de conexión mediante SSLv3 no produjo una respuesta interpretable con las herramientas disponibles en el entorno de prueba, por lo que este protocolo específico no pudo validarse de forma concluyente y se recomienda confirmarlo con una herramienta especializada adicional, como testssl.sh, en una fase posterior.

Figura 3.3 Resultado de la validación de protocolos TLS mediante OpenSSL



```
(kali) [~]
$ echo | openssl s_client -connect impuestos.gob.bo:443 -tls1_2 2>&1 | grep -E "Protocol|Cipher"
New, TLSv1.2, Cipher is ECDHE-RSA-AES256-GCM-SHA384
Protocol: TLSv1.2
Cipher      : ECDHE-RSA-AES256-GCM-SHA384

(kali) [~]
$ echo | openssl s_client -connect impuestos.gob.bo:443 -tls1 2>&1 | grep -E "Protocol|Cipher|error|alert"
New, TLSv1.0, Cipher is ECDHE-RSA-AES256-SHA
Protocol: TLSv1
Cipher    : ECDHE-RSA-AES256-SHA
```

En consecuencia, el caso de prueba WSTG-CRYP-01 se considera confirmado: si bien el servidor prioriza y soporta TLS 1.2 con cifrado robusto, continúa aceptando conexiones mediante TLS 1.0, un protocolo obsoleto que representa una debilidad de configuración en la capa de transporte.

3.3.7 WSTG-CONF-06 Métodos HTTP habilitados

Este caso de prueba busca enumerar los métodos HTTP admitidos por el servidor, con el propósito de identificar la habilitación de métodos potencialmente peligrosos como PUT, DELETE o TRACE que puedan permitir la modificación de recursos o ataques de Cross-Site Tracing (XST) (OWASP, 2020). Este caso de prueba no proviene de un hallazgo preliminar de las herramientas automatizadas empleadas en el Capítulo II, sino que se incorporó como parte de la aplicación directa de la metodología OWASP WSTG.

La validación se realizó mediante tres solicitudes HTTP directas. Una solicitud OPTIONS fue respondida con el código 200 OK, sin exponer explícitamente un encabezado Allow que enumerara los métodos permitidos. Una solicitud TRACE fue rechazada con el código 405 (Method Not Allowed), lo que constituye una configuración adecuada que previene ataques de Cross-Site Tracing. Sin embargo, una solicitud PUT fue respondida con el código 200 (OK), un resultado inesperado para un método que, en un servidor de producción correctamente configurado, debería ser rechazado con un código 403 o 405.

Figura 3.4 Resultado de la validación de métodos HTTP habilitados

```
(kali@kali)-[~]
$ curl -s -I -X OPTIONS https://impuestos.gob.bo
HTTP/1.1 200 OK
Date: Sun, 19 Jul 2026 13:27:28 GMT
Server: Apache/2.4.52 (Ubuntu)
Link: <https://www.impuestos.gob.bo/index.php/wp-json/>; rel="https://api.w.org/"
Vary: Accept-Encoding
Content-Type: text/html; charset=UTF-8
Set-Cookie: cookiesession1=678B2867CE6177CCBEE83219FC7B27C5;Expires=Mon, 19 Jul 2027 13:27:28 GMT;Path=/;HttpOnly
content-length: 158517

(kali@kali)-[~]
$ curl -s -o /dev/null -w "%{http_code}\n" -X TRACE https://impuestos.gob.bo
405
$ curl -s -o /dev/null -w "%{http_code}\n" -X PUT https://impuestos.gob.bo
200
```

Es importante precisar que esta validación se limitó a observar el código de respuesta del servidor y no incluyó el envío de contenido ni la verificación de si el método PUT permite efectivamente crear o modificar recursos en el servidor, ya que dicha comprobación excedería el alcance no intrusivo definido para la presente investigación. En consecuencia, el caso de prueba WSTG-CONF-06 se considera confirmado: el método TRACE se encuentra correctamente restringido, pero la ausencia de rechazo explícito del método PUT constituye una debilidad de configuración que amerita revisión administrativa, sin que ello implique una confirmación de explotabilidad.

3.3.8 WSTG-ERRH-01 Manejo de errores

Este caso de prueba busca determinar si el servidor revela información técnica excesiva como rutas internas, trazas de pila (stack traces) o versiones de software al generar respuestas de error ante solicitudes inválidas o inexistentes (OWASP, 2020). Al igual que el caso anterior, no proviene de un hallazgo preliminar automatizado, sino de la aplicación directa de la metodología.

La validación se inició solicitando una ruta deliberadamente inexistente del portal. El servidor respondió con un código 301 (Moved Permanently) y el encabezado X-Redirect-By: WordPress, redirigiendo hacia la misma ruta bajo el subdominio www. Este comportamiento corresponde al mecanismo de redirección canónica de WordPress para rutas no reconocidas, y antecede a la página de error definitiva del sitio.

Siguiendo la redirección con la opción -L de curl, se obtuvo el contenido íntegro de la página de error definitiva. El servidor respondió con una página HTML personalizada de error 404, titulada «Página no encontrada - 404», que incluye una hoja de estilos propia y un mensaje genérico para el usuario («Lo sentimos, la página que buscas no existe o fue movida»), junto con un enlace de retorno al inicio del portal.

El análisis del código fuente de esta página no evidenció información técnica sensible: no se observaron rutas internas del servidor, trazas de pila (stack traces), consultas SQL, números de línea de código, ni versiones de software adicionales a las ya identificadas en los casos de prueba anteriores. El contenido se limita a marcado HTML y CSS de presentación, propio de una página de error personalizada de WordPress.

En consecuencia, el caso de prueba WSTG-ERRH-01 se considera no confirmado: si bien el servidor expone un encabezado no estándar y un código de redirección propios de WordPress, la página de error definitiva no revela información técnica excesiva, lo que constituye una buena práctica de manejo de errores por parte del portal evaluado.

Figura 3.5 Resultado de la solicitud a una ruta inexistente del portal



```
(kali@kali)-[~]
$ curl -sL https://impuestos.gob.bo/paginaquenoexiste12345 | head -c 2000
<!DOCTYPE html>
<html lang="es">
<head>
  <meta charset="UTF-8">
  <meta name="viewport" content="width=device-width, initial-scale=1.0">
  <title>Página no encontrada - 404</title>
  <link rel="stylesheet" href="404.css">
  <style>
```

3.3.9 Verificación complementaria mediante herramientas de análisis pasivo

Con el fin de reforzar los hallazgos de configuración y de cifrado obtenidos mediante la validación manual descrita en los apartados 3.3.4 y 3.3.6, se aplicaron de forma adicional tres servicios de análisis exclusivamente pasivo, coherentes con el alcance no intrusivo definido para la presente investigación: Security Headers, Mozilla HTTP Observatory y Qualys SSL Labs, complementados con una consulta a los registros públicos de Certificate Transparency mediante crt.sh.

a) Cabeceras de seguridad HTTP.

Security Headers calificó al portal con la nota F, confirmando la ausencia de las seis cabeceras ya identificadas en el apartado 3.3.4 (Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy y Permissions-Policy), y evidenciando nuevamente el encabezado Server: Apache/2.4.52 (Ubuntu), consistente con el hallazgo WSTG-INFO-02.

Figura 3.6 Reporte de Security Headers sobre el portal evaluado

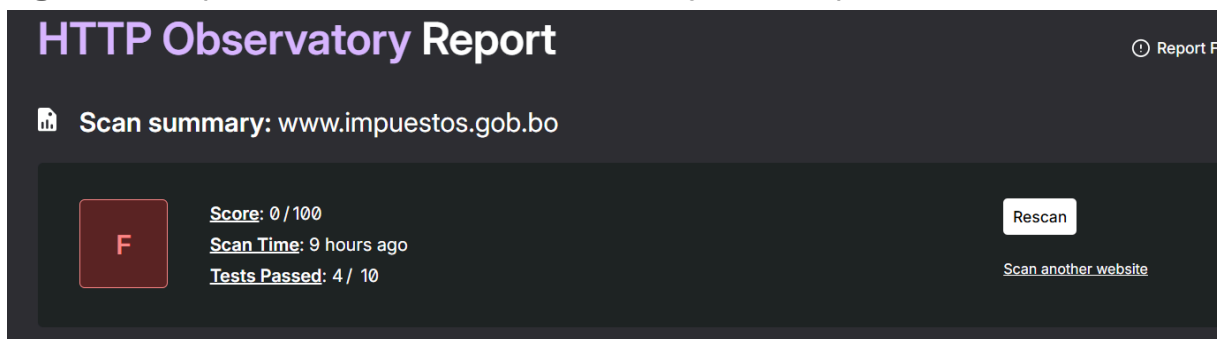
The image shows the Security Headers by snyk interface. At the top, there's a red banner with the "Security Headers by snyk" logo and a "Scan your site now" button. Below this, a search bar contains the URL "https://www.impuestos.gob.bo/" and a "Scan" button. There are also checkboxes for "Hide results" and "Follow redirects".

Below the banner is a "Security Report Summary" section. It features a large red square with a white letter "F" on the left. To the right, the following information is displayed:

- Site: <https://www.impuestos.gob.bo/>
- IP Address: 170.82.244.41
- Report Time: 19 Jul 2026 15:09:13 UTC
- Headers: A list of missing headers in red boxes: Strict-Transport-Security, Content-Security-Policy, X-Frame-Options, X-Content-Type-Options, Referrer-Policy, and Permissions-Policy.
- Advanced: A message stating "Ouch, you should work on your security posture immediately." with a "Start Now" button.

Mozilla HTTP Observatory corroboró el resultado de forma independiente, con una calificación de 0/100 (nota F) y 4 de 10 pruebas superadas, penalizando específicamente la ausencia de Content Security Policy (-25), Strict Transport Security (-20), X-Frame-Options (-20), Subresource Integrity (-5) y X-Content-Type-Options (-5). El que dos servicios independientes coincidan con la validación manual del apartado 3.3.4 refuerza la validez del hallazgo confirmado.

Figura 3.7 Reporte de Mozilla HTTP Observatory sobre el portal evaluado



Mozilla HTTP Observatory también penalizó (-40) la cookie de sesión por no utilizar el atributo Secure. A diferencia de lo señalado inicialmente en el apartado 3.3.5, esta segunda fuente independiente coincidió con el resultado de Security Headers, lo que motivó una nueva revisión manual mediante Burp Suite Community. Dicha revisión confirmó que el atributo Secure efectivamente no está presente en la cabecera Set-Cookie enviada por el servidor, por lo que el caso de prueba WSTG-SESS-02 se reclasifica como confirmado (véase la conclusión actualizada del apartado 3.3.5).

b) Configuración de la capa de transporte.

SSL Labs calificó al servidor con la nota B, calificación limitada por el soporte de TLS 1.0 y TLS 1.1, lo que confirma de manera independiente el hallazgo WSTG-CRYP-01 validado manualmente en el apartado 3.3.6. De manera relevante, esta herramienta permite resolver la limitación señalada en dicho apartado: se confirma de forma concluyente que el servidor no admite SSLv3 ni SSLv2, lo cual descarta la presencia de las vulnerabilidades asociadas a dichos protocolos (por ejemplo, POODLE). Asimismo, se verificó que el certificado del servidor (RSA de 2048 bits, emitido por RapidSSL, entidad perteneciente a DigiCert) es válido y no se encuentra revocado, que el servidor no es vulnerable a Heartbleed, ROBOT ni POODLE, y que mantiene compatibilidad con Forward Secrecy de forma robusta. Se identificó, además, que el ataque BEAST no se encuentra mitigado del lado del servidor para conexiones mediante TLS 1.0, un detalle adicional que agrava levemente el hallazgo ya confirmado, sin modificar su nivel de criticidad medio.

Figura 3.8 Reporte de Qualys SSL Labs sobre la configuración de la capa de transporte del portal evaluado



c) Reconocimiento pasivo de subdominios mediante Certificate Transparency (caso WSTG-INFO-04).

La consulta a los registros públicos de Certificate Transparency mediante crt.sh una técnica completamente pasiva que no realiza ninguna solicitud directa al servidor evaluado, sino que consulta logs públicos de autoridades certificadoras permitió identificar subdominios del portal no detectados durante el reconocimiento inicial con WhatWeb y Wappalyzer (apartado 2.4), entre ellos test.idp.impuestos.gob.bo, expe.pruebas.impuestos.gob.bo, sac.impuestos.gob.bo, bbb.impuestos.gob.bo, chat2.impuestos.gob.bo y culturatributaria-naf.impuestos.gob.bo. La nomenclatura de al menos dos de ellos ("test", "pruebas") sugiere la existencia de entornos de prueba o reproducción potencialmente expuestos de forma pública.

Figura 3.9 Consulta de Certificate Transparency del dominio impuestos.gob.bo mediante crt.sh

crt.sh

Identity Search

CSV

JSON

Group by Issuer

Criteria

Type: Identity

Match: ILIKE

Search: 'impuestos.gob.bo'

Certificates	crt.sh ID	Logged At	Not Before	Not After	Common Name	Matching Identities	Issuer Name
	24492171673	2026-02-18	2026-02-18	2027-02-17	*.impuestos.gob.bo	*.impuestos.gob.bo impuestos.gob.bo	C=US,O=DigiCert Inc,OU=www.digicert.com,CN=RapidSSL_TLS_RSA_CA_G1
	22624229918	2025-11-20	2025-11-20	2026-02-18	bbb.impuestos.gob.bo	bbb.impuestos.gob.bo	C=US,O=Let's Encrypt,CN=R13
	19855850675	2025-07-23	2025-07-23	2025-10-21	bbb.impuestos.gob.bo	bbb.impuestos.gob.bo	C=US,O=Let's Encrypt,CN=R10
	19857460887	2025-07-23	2025-07-23	2025-10-21	bbb.impuestos.gob.bo	bbb.impuestos.gob.bo	C=US,O=Let's Encrypt,CN=R10
	18595392584	2025-05-24	2025-05-24	2025-08-22	bbb.impuestos.gob.bo	bbb.impuestos.gob.bo	C=US,O=Let's Encrypt,CN=R11
	18595551942	2025-05-24	2025-05-24	2025-08-22	bbb.impuestos.gob.bo	bbb.impuestos.gob.bo	C=US,O=Let's Encrypt,CN=R11
	17377944678	2025-03-24	2025-03-24	2025-06-22	bbb.impuestos.gob.bo	bbb.impuestos.gob.bo	C=US,O=Let's Encrypt,CN=R10
	17378293840	2025-03-24	2025-03-24	2025-06-22	bbb.impuestos.gob.bo	bbb.impuestos.gob.bo	C=US,O=Let's Encrypt,CN=R10
	17059173129	2025-03-11	2025-03-11	2025-06-09	*.impuestos.gob.bo	*.impuestos.gob.bo impuestos.gob.bo	C=AT,O=ZeroSSL,CN=ZeroSSL_RSA_Domain_Secure_Site_CA
	17059174758	2025-03-11	2025-03-11	2025-06-09	*.impuestos.gob.bo	*.impuestos.gob.bo impuestos.gob.bo	C=AT,O=ZeroSSL,CN=ZeroSSL_RSA_Domain_Secure_Site_CA

Este hallazgo se incorpora como el caso de prueba WSTG-INFO-04 Enumeración de aplicaciones dentro del alcance del servidor web (OWASP, 2020), y se clasifica como confirmado, categoría A05:2021 Security Misconfiguration, CWE-200, con un nivel de criticidad informativa, dado que el alcance no intrusivo del presente estudio no permitió evaluar directamente el estado de hardening de dichos subdominios.

En conjunto, esta verificación complementaria no solo refuerza mediante fuentes independientes los hallazgos ya confirmados en el apartado 3.3, sino que resuelve la limitación pendiente sobre SSLv3 y añade un nuevo caso de prueba de carácter informativo, ampliando de ocho a nueve el total de casos considerados en la presente investigación.

3.4 Clasificación de los hallazgos

Con base en los nueve casos de prueba validados en el apartado 3.3 incluyendo la verificación complementaria del apartado 3.3.9, la Tabla 3.2 sintetiza el resultado de cada validación, su categoría según el OWASP Top 10:2021 (OWASP, 2021) o el identificador CWE asociado (MITRE Corporation, n.d.-b), y su nivel de criticidad. Para la determinación de la criticidad se empleó una escala cualitativa de cuatro niveles alto, medio, bajo e informativo, consistente con los criterios de determinación de riesgo basados en la probabilidad de explotación y el impacto potencial descritos por Scarfone et al. (2008), y ajustada al alcance de reconocimiento no intrusivo de caja negra definido para la presente investigación. Los hallazgos descartados durante la validación manual (no confirmados) no reciben categoría OWASP Top 10 ni CWE, dado que no constituyen una debilidad real del sistema evaluado.

Tabla 3.2 Clasificación de los hallazgos validados según resultado, categoría OWASP Top 10:2021, CWE y nivel de criticidad

Hallazgo / Caso WSTG	Resultado de la validación	Categoría OWASP Top 10:2021	CWE asociado	Criticidad
----------------------	----------------------------	-----------------------------	--------------	------------

WSTG-INFO-02 Divulgación de la versión del servidor web	Confirmado	A05:2021 Security Misconfiguration	CWE-200	Bajo / Informativo
WSTG-INFO-08 Divulgación de tecnologías y framework de aplicación	Confirmado	A05:2021 Security Misconfiguration	CWE-200	Bajo / Informativo
WSTG-CONF-02 Exposición del endpoint de la API REST (wp-json)	confirmado	A05:2021 Security Misconfiguration	CWE-200	Medio
WSTG-CONF-07 / WSTG-CONF-14 Ausencia de cabeceras HTTP de seguridad	Confirmado	A05:2021 Security Misconfiguration	CWE-693	Medio
WSTG-SESS-02 Cookie de sesión sin atributo Secure	Confirmado	A05:2021 Security Misconfiguration	CWE-614	Medio
WSTG-CRYP-01 Aceptación de conexiones mediante TLS 1.0	Confirmado	A02:2021 Cryptographic Failures	CWE-326	Medio
WSTG-CONF-06 Método HTTP PUT habilitado	Parcialmente confirmado	A05:2021 Security Misconfiguration	CWE-650	Medio
WSTG-ERRH-01 Manejo de páginas de error	No confirmado (buena práctica)	No aplica	No aplica	Informativo
WSTG-INFO-04 Enumeración de subdominios mediante Certificate Transparency (crt.sh)	Confirmado	A05:2021 Security Misconfiguration	CWE-200	Informativo

Nota. Elaboración propia a partir de la validación manual descrita en el apartado 3.3, la clasificación OWASP Top 10:2021 (OWASP, 2021), el catálogo CWE (MITRE Corporation, n.d.-b) y los criterios de riesgo de Scarfone et al. (2008).

3.5 Resultados obtenidos

De los nueve casos de prueba de la metodología **OWASP Web Security Testing Guide (WSTG)** ejecutados durante la validación (apartados 3.3.1 a 3.3.9), **siete fueron confirmados** (WSTG-INFO-02, WSTG-INFO-08, WSTG-CONF-02, WSTG-CONF-07/WSTG-CONF-14, WSTG-SESS-02, WSTG-CRYP-01 y WSTG-INFO-04), **uno fue parcialmente confirmado** (WSTG-CONF-06) y **uno no fue confirmado** (WSTG-ERRH-01). En conjunto, **ocho de los nueve casos de prueba (88,9%)** evidenciaron configuraciones o condiciones de seguridad relevantes para la evaluación del portal, mientras que **un caso (11,1%)** correspondió a una buena práctica correctamente implementada, relacionada con el manejo de páginas de error.

El caso **WSTG-INFO-04** fue incorporado como resultado de la verificación complementaria mediante herramientas de análisis pasivo, descrita en el apartado 3.3.9. Asimismo, las herramientas **Security Headers**, **Mozilla Observatory**, **SSL Labs** y **crt.sh** permitieron corroborar de manera independiente varios de los hallazgos obtenidos inicialmente durante el diagnóstico, fortaleciendo la evidencia asociada a los casos **WSTG-INFO-02**, **WSTG-CONF-07/WSTG-CONF-14**, **WSTG-SESS-02** y **WSTG-CRYP-01**, además de ampliar la información obtenida durante la fase de reconocimiento mediante la enumeración de certificados y subdominios públicos.

Considerando los hallazgos identificados inicialmente mediante herramientas automatizadas durante el Capítulo II, la aplicación de la metodología **OWASP WSTG** permitió confirmar la mayoría de ellos y establecer con mayor precisión el alcance e impacto de cada resultado. En particular, el caso **WSTG-CONF-02**, correspondiente a la exposición del endpoint **wp-json**, fue confirmado durante la validación manual, determinándose que su existencia representa un riesgo de divulgación de información y facilita el reconocimiento de tecnologías, aunque su impacto depende del contexto de implementación y no constituye por sí mismo una vulnerabilidad crítica. Asimismo, el caso **WSTG-CONF-06**, incorporado directamente como parte de la metodología WSTG, permitió identificar la habilitación del método HTTP PUT, ampliando el alcance de la evaluación más allá de los hallazgos detectados por las herramientas automatizadas.

En cuanto a la clasificación de criticidad, **cinco hallazgos** fueron clasificados con **criticidad media**, mientras que **tres** correspondieron a una **criticidad baja o informativa**. La categoría predominante de **OWASP Top 10:2021** fue **A05:2021 – Security Misconfiguration**, presente en **siete de los ocho hallazgos confirmados o parcialmente confirmados**, lo que evidencia que la principal superficie de mejora del portal evaluado está relacionada con configuraciones de seguridad. Por su parte, el caso **WSTG-CRYP-01** fue clasificado dentro

de la categoría **A02:2021 – Cryptographic Failures**, debido a la aceptación de conexiones mediante versiones antiguas del protocolo TLS.

Finalmente, los resultados obtenidos guardan relación directa con los objetivos específicos planteados en el Capítulo I. Se identificaron las tecnologías y servicios expuestos del portal (objetivo específico 1), se detectaron posibles vulnerabilidades mediante herramientas automatizadas (objetivo específico 2), se clasificaron los hallazgos de acuerdo con su nivel de criticidad y su relación con las categorías de seguridad web (objetivo específico 3) y se validaron manualmente mediante la metodología **OWASP Web Security Testing Guide**, diferenciando aquellos hallazgos efectivamente confirmados de los que no representaban una debilidad de seguridad (objetivo específico 4). Finalmente, los resultados obtenidos constituyen la base para las recomendaciones orientadas al fortalecimiento de la seguridad del portal, presentadas en las conclusiones de la presente monografía.

3.6 Conclusiones capitulares

El proceso de validación descrito en este capítulo demuestra que las herramientas automatizadas de reconocimiento, si bien resultan eficientes para obtener una primera aproximación al estado de seguridad de una aplicación web, no son suficientes por sí solas para determinar con certeza la existencia real de una vulnerabilidad. La aplicación sistemática de la metodología OWASP Web Security Testing Guide permitió precisar el alcance real de dos hallazgos que las herramientas habían reportado de forma parcial o ambigua (WSTG-CONF-02 y WSTG-CONF-06), y confirmar técnicamente cinco debilidades de configuración presentes en el portal (WSTG-INFO-02, WSTG-INFO-08, WSTG-CONF-07/CONF-14, WSTG-SESS-02 y WSTG-CRYP-01). En particular, el caso WSTG-SESS-02 puso de manifiesto que incluso una técnica de validación manual, si se aplica de forma aislada, puede arrojar un resultado engañoso: solo al contrastar con una segunda técnica de inspección directa fue posible confirmar que la cookie de sesión carecía efectivamente del atributo Secure.

Asimismo, la aplicación directa de la metodología WSTG más allá de los hallazgos originados en las herramientas automatizadas permitió incorporar dos casos de prueba adicionales (WSTG-CONF-06 y WSTG-ERRH-01) que ampliaron la profundidad del análisis, revelando una debilidad de configuración en los métodos HTTP habilitados que ninguna de las herramientas del Capítulo II había detectado. Este resultado constituye uno de los principales aportes de la investigación, ya que evidencia el valor añadido de complementar el reconocimiento automatizado con un proceso de validación estructurado y basado en una metodología reconocida internacionalmente.

En conjunto, los hallazgos confirmados y clasificados en el apartado 3.4 constituyen la base técnica sobre la cual se desarrollará, en el Capítulo IV, la validación del cumplimiento de los objetivos planteados en el Capítulo I, así como las conclusiones generales y las recomendaciones de fortalecimiento de la seguridad del Portal Web del Servicio de Impuestos Nacionales de Bolivia.

En cumplimiento del carácter obligatorio de publicación establecido por la guía del Módulo de Trabajo Final, todo el desarrollo correspondiente a la presente propuesta incluyendo los comandos ejecutados, los resultados completos de las herramientas empleadas y demás evidencias técnicas se encuentra disponible de forma pública en el siguiente repositorio de GitHub:

<https://github.com/Jovetic2708/Validaci-n-de-vulnerabilidades-web-con-OWASP-Joseph-David-Coria-Rojas.git>

Capítulo IV

VALIDACIÓN

4.1 Introducción capitular

El presente capítulo tiene como propósito validar el grado de cumplimiento de los objetivos planteados en el Capítulo I a partir de los resultados obtenidos durante el proceso de reconocimiento automatizado (Capítulo II) y de validación manual mediante la metodología OWASP Web Security Testing Guide (Capítulo III). A diferencia de la validación técnica caso por caso desarrollada en el apartado 3.3, este capítulo se centra en evaluar la propuesta metodológica en su conjunto: en qué medida la aplicación de la metodología OWASP WSTG contribuyó efectivamente a validar las vulnerabilidades identificadas mediante herramientas automatizadas, y en qué medida ello responde a la formulación del problema planteada en el Capítulo I.

4.2 Metodología de validación

Dado que la presente investigación corresponde a un estudio de caso único el Portal Web del Servicio de Impuestos Nacionales de Bolivia y no a una muestra estadística de sistemas, la validación de la propuesta se realizó mediante criterios cualitativos, complementados con indicadores cuantitativos simples de conteo y proporción. Se emplearon los siguientes criterios e indicadores:

a) Tasa de discriminación de falsos positivos: proporción de hallazgos automatizados descartados tras la validación manual, respecto del total de hallazgos preliminares reportados por las herramientas automatizadas en el Capítulo II.

b) Profundidad del análisis: número de debilidades adicionales identificadas mediante la aplicación directa de la metodología WSTG, no detectadas por las herramientas automatizadas empleadas.

c) Consistencia con estándares de clasificación: correspondencia de cada hallazgo confirmado con una categoría del OWASP Top 10:2021 (OWASP, 2021) o un identificador CWE (MITRE Corporation, n.d.-b), y asignación de un nivel de criticidad conforme a los criterios de riesgo de Scarfone et al. (2008).

d) Cobertura de los objetivos específicos: contraste directo entre cada objetivo específico planteado en el Capítulo I y el apartado del trabajo en el que dicho objetivo fue atendido.

4.3 Escenarios y casos de prueba considerados

La validación se realizó sobre los nueve casos de prueba de la metodología OWASP WSTG ejecutados en el apartado 3.3 (WSTG-INFO-02, WSTG-INFO-08, WSTG-CONF-02, WSTG-CONF-07/CONF-14, WSTG-SESS-02, WSTG-CRYP-01, WSTG-CONF-06, WSTG-ERRH-01 y WSTG-INFO-04), aplicados sobre el entorno de producción del Portal Web del Servicio de Impuestos Nacionales, bajo un enfoque de caja negra y de carácter no intrusivo, utilizando las herramientas descritas en los Capítulos II y III: WhatWeb, Wappalyzer, Nikto, Nuclei, Burp Suite Community, OpenSSL, las herramientas de desarrollo de Google Chrome y solicitudes HTTP directas mediante curl.

A modo de síntesis, la Tabla 4.1 presenta una matriz de trazabilidad que integra, para cada uno de los nueve casos de prueba ejecutados, la evidencia técnica que sustenta su resultado, el estado final de validación y el nivel de criticidad asignado, permitiendo visualizar de manera conjunta el recorrido completo desde el hallazgo preliminar hasta su interpretación final.

Tabla 4.1 *Matriz de trazabilidad de los hallazgos validados*

Hallazgo / Caso WSTG	Evidencia utilizada	Estado	Criticidad
WSTG-INFO-02 — Divulgación de versión del servidor	Nikto (Cap. II); Burp Suite y curl (3.3.1)	Confirmado	Bajo
WSTG-INFO-08 — Divulgación de tecnologías/framework	Wappalyzer, Nikto (Cap. II); Burp Suite y curl (3.3.2)	Confirmado	Bajo

WSTG-CONF-02 — Exposición del endpoint wp-json	Nikto (Cap. II); curl directo (3.3.3)	confirmado	Medio
WSTG-CONF-07/14 — Ausencia de cabeceras HTTP	Nikto (Cap. II); Burp Suite (3.3.4)	Confirmado	Medio
WSTG-SESS-02 — Cookie sin atributo Secure	Nikto, Nuclei (Cap. II); Chrome DevTools y Burp Suite (3.3.5)	Confirmado	Medio
WSTG-CRYP-01 — Aceptación de TLS 1.0	Nikto (Cap. II); OpenSSL (3.3.6); SSL Labs (3.3.9)	Confirmado	Medio
WSTG-CONF-06 — Método HTTP PUT habilitado	curl directo (3.3.7)	Parcialmente confirmado	Medio
WSTG-ERRH-01 — Manejo de páginas de error	curl directo (3.3.8)	No confirmado (buena práctica)	Informativo
WSTG-INFO-04 — Enumeración de subdominios (crt.sh)	crt.sh (3.3.9)	Confirmado	Informativo

Nota. Elaboración propia a partir de la ejecución de los casos de prueba descrita en el apartado 3.3 y la clasificación de la Tabla 3.2.

4.4 Análisis comparativo: reconocimiento automatizado frente a validación asistida por OWASP WSTG

El Capítulo II generó diversos hallazgos preliminares mediante herramientas automatizadas. La aplicación de la metodología OWASP WSTG en el Capítulo III permitió validar técnicamente dichos resultados, confirmando siete hallazgos, confirmando parcialmente uno y descartando un caso de prueba que correspondía a una buena práctica de seguridad ya implementada. Este proceso permitió clasificar cada hallazgo según su criticidad, asociarlo a categorías del OWASP Top 10:2021 y determinar su relevancia dentro del contexto evaluado.

Adicionalmente, la aplicación directa de la metodología más allá de los hallazgos originados en las herramientas automatizadas permitió identificar una debilidad de configuración adicional relacionada con los métodos HTTP habilitados (WSTG-CONF-06), no detectada por WhatWeb, Wappalyzer, Nikto ni Nuclei. Este contraste evidencia que un pentest asistido por la metodología OWASP WSTG aporta una capa de profundidad y de discriminación técnica que el reconocimiento automatizado, por su propia naturaleza, no puede ofrecer por sí solo.

4.5 Interpretación de resultados en relación con los objetivos

El objetivo específico 1 identificar las tecnologías y servicios expuestos del portal se cumplió satisfactoriamente mediante el reconocimiento con WhatWeb y Wappalyzer descrito en el apartado 2.4, posteriormente ampliado en el apartado 3.3.3 mediante la inspección del endpoint de la API REST de WordPress. El objetivo específico 2 detectar posibles vulnerabilidades mediante herramientas automatizadas se cumplió mediante el análisis con Nikto y Nuclei descrito en el apartado 2.5.

El objetivo específico 3 clasificar los hallazgos según su nivel de criticidad y su relación con las categorías de seguridad web se cumplió mediante la Tabla 3.2 del apartado 3.4, que asoció cada hallazgo validado con una categoría del OWASP Top 10:2021, un identificador CWE cuando correspondía, y un nivel de criticidad. El objetivo específico 4 validar manualmente las vulnerabilidades mediante la metodología OWASP WSTG para determinar la existencia de vulnerabilidades reales y falsos positivos se cumplió mediante el desarrollo íntegro del apartado 3.3, que permitió confirmar, confirmar parcialmente o descartar cada uno de los nueve casos de prueba ejecutados.

El objetivo específico 5 proponer recomendaciones orientadas a fortalecer la seguridad del portal se atiende en el apartado de recomendaciones que cierra la presente monografía, formulado a partir de los hallazgos confirmados y clasificados en el Capítulo III.

En cuanto al objetivo general validar las vulnerabilidades web identificadas mediante herramientas automatizadas utilizando la metodología OWASP WSTG en el Portal Web del Servicio de Impuestos Nacionales de Bolivia, los resultados obtenidos permiten afirmar que se cumplió satisfactoriamente: ocho de los nueve casos de prueba ejecutados fueron confirmados o parcialmente confirmados como debilidades reales de configuración, con su respectiva categoría y nivel de criticidad, mientras que el caso restante (WSTG-ERRH-01) fue adecuadamente descartado con sustento técnico como una buena práctica ya implementada. Ello responde también a la formulación del problema planteada en el Capítulo I: la metodología OWASP WSTG contribuyó concretamente validando los hallazgos reportados por las herramientas automatizadas, precisando su alcance real, determinando su criticidad e identificando debilidades adicionales que no habían sido detectadas durante el reconocimiento automatizado.

4.6 Conclusiones capitulares

La validación desarrollada en este capítulo confirma que la propuesta metodológica planteada en el Capítulo III la aplicación de la metodología OWASP Web Security Testing Guide como complemento del reconocimiento automatizado responde adecuadamente al objetivo general y a los objetivos específicos de la investigación. Los resultados obtenidos evidencian que la metodología permitió validar técnicamente los hallazgos detectados, determinar su nivel de criticidad, asociarlos con estándares reconocidos de seguridad web y complementar la información obtenida mediante herramientas automatizadas. Asimismo, el alcance no intrusivo y de caja negra definido para la investigación limitó la posibilidad de verificar de manera concluyente ciertos aspectos relacionados con la explotabilidad efectiva de algunas configuraciones detectadas, particularmente el método HTTP PUT identificado en el caso WSTG-CONF-06. No obstante, los resultados obtenidos constituyen evidencia suficiente para sustentar las conclusiones generales y las recomendaciones formuladas en la presente monografía.

CONCLUSIONES Y RECOMENDACIONES

Conclusiones

La presente monografía tuvo como objetivo general validar las vulnerabilidades web identificadas mediante herramientas automatizadas utilizando la metodología OWASP Web Security Testing Guide en el Portal Web del Servicio de Impuestos Nacionales de Bolivia. A partir de los resultados obtenidos en los cuatro capítulos precedentes, se concluye que dicho objetivo fue cumplido satisfactoriamente.

El reconocimiento automatizado realizado con WhatWeb, Wappalyzer, Nikto y Nuclei (Capítulo II) permitió identificar el conjunto de tecnologías empleadas por el portal y un total de nueve hallazgos preliminares de seguridad, cumpliendo con los dos primeros objetivos específicos de la investigación. Sin embargo, dichos hallazgos, por sí solos, no permitían determinar con certeza cuáles constituían vulnerabilidades reales.

La validación manual basada en la metodología OWASP WSTG (Capítulo III) permitió confirmar siete hallazgos, confirmar parcialmente uno y descartar un caso de prueba correspondiente a una buena práctica de seguridad ya implementada. Además, permitió identificar una debilidad adicional relacionada con la habilitación del método HTTP PUT, ampliando el alcance del análisis realizado inicialmente mediante herramientas automatizadas.

El análisis conjunto de los hallazgos confirmados evidencia que la categoría predominante de debilidad en el portal evaluado corresponde a errores de configuración de seguridad

(A05:2021 Security Misconfiguration), presentes en la divulgación de información técnica (versión del servidor, tecnologías empleadas y estructura de la API REST), la ausencia de cabeceras HTTP de seguridad y la habilitación de métodos HTTP innecesarios, mientras que únicamente un hallazgo correspondió a una falla criptográfica (A02:2021 Cryptographic Failures), relacionada con la aceptación de conexiones mediante TLS 1.0. Ningún hallazgo confirmado alcanzó un nivel de criticidad alto, lo que sugiere que el portal evaluado presenta una base de seguridad razonable, si bien perfectible en aspectos puntuales de configuración.

En este sentido, el objetivo general de la investigación se cumplió: la metodología OWASP WSTG demostró contribuir efectivamente a la validación de las vulnerabilidades identificadas mediante herramientas automatizadas, validando técnicamente los hallazgos detectados, precisando su alcance real, determinando su criticidad e identificando debilidades adicionales que no habían sido detectadas inicialmente.

Cabe señalar, como limitación del estudio, que el alcance no intrusivo y de caja negra definido para esta investigación impidió verificar de manera concluyente la explotabilidad efectiva de algunas configuraciones detectadas, particularmente la relacionada con el método HTTP PUT, cuya validación completa requeriría un alcance de evaluación diferente o autorización explícita para realizar pruebas más profundas.

Recomendaciones

A partir de los hallazgos confirmados y clasificados en el Capítulo III, se plantean las siguientes recomendaciones orientadas al fortalecimiento de la seguridad del Portal Web del Servicio de Impuestos Nacionales de Bolivia:

1. Implementar las cabeceras HTTP de seguridad actualmente ausentes Strict-Transport-Security (HSTS), Content-Security-Policy (CSP), X-Content-Type-Options, Permissions-Policy y Referrer-Policy, conforme a las recomendaciones de OWASP, como parte de una estrategia de defensa en profundidad.
2. Deshabilitar el soporte del protocolo TLS 1.0 en la configuración del servidor web, conservando únicamente versiones de TLS consideradas seguras (TLS 1.2 y TLS 1.3), y confirmar mediante una herramienta especializada como testssl.sh si el servidor acepta además el protocolo SSLv3, para deshabilitarlo de ser el caso.
3. Restringir a nivel de servidor web o de firewall de aplicaciones web (WAF) los métodos HTTP innecesarios, en particular PUT, devolviendo un código de respuesta 403 o 405 ante solicitudes que utilicen dicho método.
4. Reducir la divulgación de información técnica del portal, suprimiendo o generalizando el encabezado Server que expone la versión exacta del servidor web, y restringiendo o limitando mediante control de acceso la información detallada de complementos y módulos expuesta a través del endpoint de la API REST de WordPress (wp-json).

5. Configurar el atributo Secure en la cookie de sesión cookiesession1, de manera que esta únicamente pueda transmitirse a través de conexiones cifradas mediante HTTPS, eliminando el riesgo de que sea interceptada en escenarios de degradación o redirección a conexiones no cifradas.
6. Incorporar un proceso periódico de gestión de vulnerabilidades que combine el reconocimiento automatizado con ciclos de validación manual basados en la metodología OWASP WSTG, de manera que los hallazgos reportados por las herramientas automatizadas sean revisados sistemáticamente antes de priorizar su corrección.
7. Revisar el acceso público a los subdominios identificados mediante Certificate Transparency que sugieren entornos de prueba o reproducción (test.idp.impuestos.gob.bo, expe.pruebas.impuestos.gob.bo, entre otros), restringiendo su exposición a Internet o dándolos de baja si ya no se encuentran en uso.
8. Como líneas de investigación futura, se recomienda ampliar el alcance de evaluación hacia pruebas de caja gris o caja blanca, así como incorporar herramientas especializadas adicionales como testssl.sh para la validación exhaustiva de protocolos criptográficos con el fin de resolver los aspectos que en la presente investigación no pudieron confirmarse de forma concluyente debido al alcance no intrusivo definido.

REFERENCIAS

- Abdulghaffar, K., Elmrabit, N., & Yousefi, M. (2023). Enhancing web application security through automated penetration testing with multiple vulnerability scanners. *Computers*, 12(11), Artículo 235.
<https://doi.org/10.3390/computers12110235>
- Banco Interamericano de Desarrollo, Organización de los Estados Americanos, & Global Cyber Security Capacity Centre. (2025). *2025 cybersecurity report: Vulnerability and maturity challenges to bridging the gaps in Latin America and the Caribbean*. Banco Interamericano de Desarrollo.
<https://publications.iadb.org/en/2025-cybersecurity-report-vulnerability-and-maturity-challenges-bridging-gaps-latin-america-and>
- Flor-Unda, O., Simbaña, F., Larriva-Novo, X., Acuña, Á., Tipán, R., & Acosta-Vargas, P. (2023). A comprehensive analysis of the worst cybersecurity vulnerabilities in Latin America. *Informatics*, 10(3), 71.
<https://doi.org/10.3390/informatics10030071>
- Horton, A., & Coles, B. (n.d.). *WhatWeb: Next generation web scanner* [Software]. GitHub. <https://github.com/urbanadventurer/WhatWeb>

- MITRE Corporation. (n.d.-a). *CVE Common Vulnerabilities and Exposures*. Recuperado el 14 de julio de 2026, de <https://www.cve.org/>
- Weidman, G. (2014). *Penetration Testing: A Hands-On Introduction to Hacking*.
- MITRE Corporation. (n.d.-b). *CWE Common Weakness Enumeration*. Recuperado el 14 de julio de 2026, de <https://cwe.mitre.org/>
- OWASP Foundation. (n.d.). *About the OWASP Foundation*. Recuperado el 14 de julio de 2026, de <https://owasp.org/about/>
- OWASP Foundation. (2020). *OWASP Web Security Testing Guide (v4.2)*. <https://owasp.org/www-project-web-security-testing-guide/v42/>
- OWASP Foundation. (2021). *OWASP Top 10:2021*. <https://owasp.org/Top10/>
- PortSwigger. (n.d.). *Burp Suite documentation*. Recuperado el 14 de julio de 2026, de <https://portswigger.net/burp/documentation>
- Mozilla. (s. f.). Mozilla Observatory. <https://developer.mozilla.org/en-US/observatory>
- Qualys. (s. f.). SSL Server Test. SSL Labs. <https://www.ssllabs.com/ssltest/>
- Security Headers. (s. f.). Security Headers. <https://securityheaders.com/>
- Sectigo Limited. (s. f.). crt.sh | Certificate Search. <https://crt.sh/>
- Sullo, C., & Hackett, D. (s. f.). Nikto Web Server Scanner. <https://github.com/sullo/nikto>
- ProjectDiscovery. (n.d.). *Nuclei overview*. Recuperado el 14 de julio de 2026, de <https://docs.projectdiscovery.io/opensource/nuclei/overview>
- Scarfone, K., Souppaya, M., Cody, A., & Orebaugh, A. (2008). *Technical guide to information security testing and assessment* (NIST Special Publication 800-115). National Institute of Standards and Technology. <https://doi.org/10.6028/NIST.SP.800-115>
- Shahid, J., Hameed, M. K., Javed, I. T., Qureshi, K. N., Ali, M., & Crespi, N. (2022). A comparative study of web application security parameters: Current trends and future directions. *Applied Sciences*, 12(8), 4077. <https://doi.org/10.3390/app12084077>
- Sullo, C. (n.d.). *Nikto2* [Software]. CIRT.net. <https://cirt.net/nikto/>

Wappalyzer. (n.d.). *About Wappalyzer*. Recuperado el 14 de julio de 2026, de <https://www.wappalyzer.com/about/>

ANEXOS

En esta sección se incorpora el material complementario que respalda los hallazgos y las validaciones descritas a lo largo de la presente monografía, y que por su extensión no forma parte del cuerpo principal del documento.

Anexo A. Herramientas utilizadas

Herramienta	Versión	Propósito
Wappalyzer	Extensión navegador	Identificación de tecnologías
Nikto	v2.6.0	Detección automatizada de configuraciones inseguras
Nuclei	v3.8.0	Identificación automatizada de posibles vulnerabilidades
Burp Suite Community	(versión instalada)	Validación manual de solicitudes HTTP
Security Headers	Plataforma web	Evaluación de cabeceras HTTP
Mozilla Observatory	Plataforma web	Evaluación de configuraciones de seguridad

SSL Labs	Plataforma web	Evaluación TLS/SSL
crt.sh	Plataforma web	Consulta de certificados públicos

Anexo B. Comandos ejecutados

nikto -h https://impuestos.gob.bo -o nikto_sin.txt -Format txt

nuclei -u https://impuestos.gob.bo -severity info,low -o nuclei_sin.txt

openssl s_client -connect impuestos.gob.bo:443

Anexo C. Resultados completos de Nikto

Nikto v2.6.0/

+ Target Host: impuestos.gob.bo

+ Target Port: 443

+ GET /: Uncommon header(s) 'x-redirect-by' found, with contents: WordPress.

+ GET /: Cookie cookiesession1 created without the secure flag. See:
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Cookies>:

+ SSL Info: Subject: /CN=*.impuestos.gob.bo

 CN: *.impuestos.gob.bo

 SAN: *.impuestos.gob.bo, impuestos.gob.bo

 Ciphers: ECDHE-RSA-AES256-GCM-SHA384

 Issuer: /C=US/O=DigiCert Inc/OU=www.digicert.com/CN=RapidSSL TLS RSA

CA G1

+ GET /: Link header(s) found with value(s):

<<https://www.impuestos.gob.bo/index.php/wp-json/>>; rel="https://api.w.org/". See:
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Link>:

- + GET /: Suggested security header missing: referrer-policy. See:
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Referrer-Policy>:
- + GET /: Suggested security header missing: strict-transport-security. See:
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Strict-Transport-Security>:
- + GET /: Suggested security header missing: permissions-policy. See:
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/Permissions-Policy>:
- + GET /: Suggested security header missing: x-content-type-options. See:
<https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Content-Type-Options>:
- + GET /: Suggested security header missing: content-security-policy. See:
<https://developer.mozilla.org/en-US/docs/Web/HTTP/CSP>:
- + GET /: Server is using a wildcard certificate: *.impuestos.gob.bo. See:
https://en.wikipedia.org/wiki/Wildcard_certificate:
- + HEAD Apache/2.4.52 appears to be outdated (current is at least 2.4.66).

Anexo D. Resultados completos de Nuclei

[azure-domain-tenant] [http] [info]
<https://login.microsoftonline.com:443/impuestos.gob.bo/v2.0/.well-known/openid-configuration>
["0b9bcc5a-f5bc-4433-b4a4-ad173d827ec9"]

[cookies-without-secure] [javascript] [info] impuestos.gob.bo ["cookiesession1"]

[dmarc-detect] [dns] [info] _dmarc.impuestos.gob.bo ["v=DMARC1; p=reject; sp=reject; rua=mailto:abuse@impuestos.gob.bo; ruf=mailto:abuse@impuestos.gob.bo; rf=afrf; pct=100; ri=86400; aspf=s; fo=1:s;"]

[mx-fingerprint] [dns] [info] impuestos.gob.bo ["10 antispam1.weblinksrl.com."]

[spf-record-detect] [dns] [info] impuestos.gob.bo ["v=spf1 mx a a:smtp-in1.impuestos.gob.bo a:smtp-in2.impuestos.gob.bo a:buzon.impuestos.gob.bo a:impuestos.gob.bo ip4:170.82.244.0/23 include:_spf.megalink.cloud -all"]

[txt-fingerprint] [dns] [info] impuestos.gob.bo
["_I24f8t5rvlq90d889c1xklul2mfgzy", "_0mn7vv1ythvxbemkt9xshlc2dhtke7m", "MS=53D2 A9EA3D4ABE52284B08CAA920A58D46316A10", "v=spf1 mx a a:smtp-in1.impuestos.gob.bo a:smtp-in2.impuestos.gob.bo a:buzon.impuestos.gob.bo"]

a:impuestos.gob.bo ip4:170.82.244.0/23 include:_spf.megalink.cloud
-all""", ""n5kv9xmr523ts9qdqg732dnvxs8hrfz4""", ""cisco-ci-domain-verification=7bf361a700515
ed60eff5ce78026c43ecfd3218265ca7e2dded542a81e109927""", ""google-site-verification=89l
gfOSB3eHKgSKrY0Z3_N98P2NZ_KC-b41d5wpA4F8""", ""google-site-verification=3wfPekR8m
WsAFg6tKYpbOnEg_LCwUZIFS1koopSldmg""", ""41gbkkk62997okrj38uqmr5puf"""]

[srv-service-detect] [dns] [info] _sip._tcp.impuestos.gob.bo ["SRV\t5 5 5060
telf-exe.impuestos.gob.bo.", "SRV\t5 5 5060 telf-exe2.impuestos.gob.bo."]

[nameserver-fingerprint] [dns] [info] impuestos.gob.bo
["ns3.MegaLink.com.", "NS5.MegaLink.com.", "ns4.MegaLink.com.", "ns2.MegaLink.com."]

[srv-service-detect] [dns] [info] _sips._tcp.impuestos.gob.bo ["SRV\t5 5 5061
telf-exe2.impuestos.gob.bo.", "SRV\t10 10 5061 telf-exe.impuestos.gob.bo."]

[srv-service-detect] [dns] [info] _sip._udp.impuestos.gob.bo ["SRV\t5 5 5060
telf-exe.impuestos.gob.bo.", "SRV\t5 5 5060 telf-exe2.impuestos.gob.bo."]

[caa-fingerprint] [dns] [info] impuestos.gob.bo

Anexo E. Resultados de Security Headers

Security Report Summary

F

Site: <https://www.impuestos.gob.bo/>

IP Address: 170.82.244.41

Report Time: 19 Jul 2026 15:09:13 UTC

Headers:

Strict-Transport-Security Content-Security-Policy X-Frame-Options X-Content-Type-Options
Referrer-Policy Permissions-Policy

Advanced:

Ouch, you should work on your security posture immediately:

Missing Headers

Strict-Transport-Security HTTP Strict Transport Security is an excellent feature to support on your site and strengthens your implementation of TLS by getting the User Agent to enforce the use of HTTPS. Recommended value "Strict-Transport-Security: max-age=31536000; includeSubDomains".

Content-Security-Policy Content Security Policy is an effective measure to protect your site from XSS attacks. By whitelisting sources of approved content, you can prevent the browser from loading malicious assets.

X-Frame-Options X-Frame-Options tells the browser whether you want to allow your site to be framed or not. By preventing a browser from framing your site you can defend against attacks like clickjacking. Recommended value "X-Frame-Options: SAMEORIGIN".

X-Content-Type-Options X-Content-Type-Options stops a browser from trying to MIME-sniff the content type and forces it to stick with the declared content-type. The only valid value for this header is "X-Content-Type-Options: nosniff".

Referrer-Policy Referrer Policy is a new header that allows a site to control how much information the browser includes with navigations away from a document and should be set by all sites.

Permissions-Policy Permissions Policy is a new header that allows a site to control which features and APIs can be used in the browser.

Anexo F. Resultados de Mozilla Observatory

<u>Content Security Policy (CSP)</u>	-25 Failed	Content Security Policy (CSP) header not implemented	Implement one, see MDN's Content Security Policy (CSP) documentation .
<u>Cookies</u>	-40 Failed	Session cookie set without using the Secure flag or set over HTTP.	Use Secure flag and set up HSTS.
<u>Cross Origin Resource Sharing (CORS)</u>	0 Passed	Content is not visible via cross-origin resource sharing (CORS) files or headers.	None
<u>Redirection</u>	0 Passed	Not able to connect via HTTP, so no redirection necessary.	None

<u>Referrer Policy</u>	-	Referrer-Policy header not implemented.	Set to strict-origin-when-cross-origin at a minimum.
<u>Strict Transport Security (HSTS)</u>	-20 Failed	Strict-Transport-Security header not implemented.	Add HSTS. Consider rolling out with shorter periods first (as suggested on https://hstspreload.org/).
<u>Subresource Integrity</u>	-5 Failed	Subresource Integrity (SRI) not implemented, but all external scripts are loaded over HTTPS.	Add SRI to external scripts.
<u>X-Content-Type-Options</u>	-5 Failed	X-Content-Type-Options header not implemented.	Set to nosniff.
<u>X-Frame-Options</u>	-20 Failed	X-Frame-Options (XFO) header not implemented.	Implement frame-ancestors CSP.
<u>Cross Origin Resource Policy</u>	-	Cross Origin Resource Policy (CORP) is not implemented (defaults to cross-origin).	None